BỘ KHOA HỌC VÀ CÔNG NGHỆ
HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG



BÁO CÁO
ĐỒ ÁN MÔN HỌC

ĐỀ TÀI: WEBSITE BÁN THIẾT BỊ MẠNG ĐẢM BẢO AN TOÀN THÔNG TIN

Môn học: An toàn ứng dụng web và cơ sở dữ liệu

Giảng viên hướng dẫn: ThS: Phan Nghĩa Hiệp

Thực hiện bởi nhóm sinh viên, bao gồm:

1.	Lê Nguyễn Khánh Duy	N22DCAT012	<Trưởng nhóm>
2.	Trần Công Hậu	N22DCAT020	<Thành viên>
3.	Thân Trung Tâm	N22DCAT047	<Thành viên>
4.	Nguyễn Phước Thanh	N22DCAT048	<Thành viên>
5.	Nguyễn Quốc Vương	N22DCAT068	<Thành viên>

TP.HCM, tháng 12 /2025

NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

Tên Sinh viên/Nhóm sinh viên:

.....
.....
.....
.....

Mã Sinh viên:

.....
.....
.....
.....

Tên Đề tài: Xây dựng hệ thống quản lý mạng cho doanh nghiệp bằng thiết bị chuyên dụng

Môn học: An toàn ứng dụng web và cơ sở dữ liệu

Giảng viên Hướng dẫn: ThS: Phan Nghĩa Hiệp

1. Nhận xét về nội dung và Kết quả đề tài

.....
.....
.....
.....
.....
.....

2. Nhận xét về thái độ và quá trình thực hiện

.....
.....
.....
.....
.....
.....

3. Đánh giá tổng quát

.....
.....
.....
.....
.....
.....

LỜI CẢM ƠN

Trước hết, nhóm chúng em xin gửi lời cảm ơn chân thành và sâu sắc đến **giảng viên hướng dẫn ThS. Phan Nghĩa Hiệp** – người đã trực tiếp giảng dạy và hướng dẫn nhóm trong suốt quá trình thực hiện đồ án môn học *An toàn ứng dụng Web và Cơ sở dữ liệu*. Thầy đã tận tình chỉ dẫn, góp ý và định hướng giúp nhóm hiểu rõ hơn các kiến thức chuyên môn, cũng như cách tiếp cận và triển khai một hệ thống web đảm bảo an toàn thông tin.

Nhóm xin chân thành cảm ơn **Học viện Công nghệ Bưu chính Viễn thông** đã tạo điều kiện thuận lợi về cơ sở vật chất, chương trình đào tạo và môi trường học tập để sinh viên có cơ hội nghiên cứu, học tập và thực hành các kiến thức đã học vào thực tế.

Bên cạnh đó, nhóm cũng xin cảm ơn các bạn bè, tập thể lớp đã luôn hỗ trợ, trao đổi và đóng góp ý kiến trong quá trình thực hiện đề tài. Những sự giúp đỡ đó đã góp phần không nhỏ vào việc hoàn thành đồ án đúng tiến độ và đạt được mục tiêu đề ra.

Mặc dù đã rất cố gắng, nhưng do thời gian và kinh nghiệm thực tế còn hạn chế, báo cáo khó tránh khỏi những thiếu sót. Nhóm rất mong nhận được sự đóng góp ý kiến và chỉ dẫn thêm từ Thầy/Cô để đồ án được hoàn thiện hơn.

Nhóm xin chân thành cảm ơn!

MỤC LỤC

CHƯƠNG I. TỔNG QUAN 8
1.1.Giới thiệu đề tài 8
1.2.Lý do chọn đề tài 9
1.3.Mục tiêu của đề tài 9
1.4.Phạm vi và đối tượng nghiên cứu 10
1.4.1.Phạm vi nghiên cứu 10
1.4.2.Đối tượng nghiên cứu 10
1.5.Ý nghĩa của đề tài 10
1.5.1.Ý nghĩa thực tiễn 10
1.5.2.Ý nghĩa học thuật 11
1.6.Bố cục báo cáo 11
CHƯƠNG II. CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ ÁP DỤNG 12
2.1.Tổng quan về an toàn ứng dụng web 12
2.2.Kiến trúc ứng dụng web hiện đại 12
2.2.1.Mô hình Client - Server 12
2.2.2.Mô hình Fullstack và next.js 12
2.3.Các lỗ hổng bảo mật phổ biến trong ứng dụng web 13
2.3.1.SQL Injection 13
2.3.2.Cross-Site Scripting (XSS) 13
2.3.3.Reflected XSS 13
2.3.4.Cross-Site Request Forgery (CSRF) 14
2.3.5.CORS Misconfiguration 14
2.3.6.Directory Traversal Vulnerabilities 15
2.4.Lỗ hổng bảo mật liên quan đến cơ sở dữ liệu 16
2.4.1.Truy cập trái phép vào cơ sở dữ liệu 16

2.4.2.Mất toàn vẹn dữ liệu 16
2.5.Lỗ hổng bảo mật liên quan đến Web Server 16
2.5.1.Cấu hình Web Server không an toàn 16
2.5.2.Tấn công từ chối dịch vụ (DoS/DDoS) 17
2.6.Lỗ hổng từ phía người dùng 17
2.6.1.Mật khẩu yếu 17
2.6.2.Thiếu nhận thức về bảo mật 17
2.7.Prisma ORM và an toàn dữ liệu 17
2.8.Tổng kết chương 18
CHƯƠNG III.PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG 19
3.1.Giới thiệu chương 19
3.2.Phân tích yêu cầu hệ thống 19
3.2.1.Các tác nhân của hệ thống 19
3.2.2.Phân tích chức năng của người dùng 22
3.2.3.Phân tích chức năng của quản trị viên 26
3.3.Thiết kế cơ sở dữ liệu 28
3.3.1.Các bảng dữ liệu chính 28
3.4.Nhận xét chương 35
CHƯƠNG IV. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN 36
4.1.Giới thiệu chương 36
4.2.Kết luận chung về đề tài 36
4.3.Đánh giá kết quả đạt được 36
4.3.1.Đánh giá về mặt chức năng hệ thống 36
4.3.2.Đánh giá về mặt thiết kế cơ sở dữ liệu 37
4.3.3.Đánh giá về mặt an toàn ứng dụng web 37

4.4.1.Giao diện người dùng (Customer) 40
4.4.2.Giao diện quản trị (Admin) 43
4.4.Những hạn chế của đề tài 45
4.5.Hướng phát triển trong tương lai 45
4.6.Tổng kết chương 45
TÀI LIỆU THAM KHẢO 46
BẢNG PHÂN CÔNG NHIỆM VỤ 47

DANH SÁCH HÌNH, BẢNG

Hình 1 . *Use Case tổng quan của hệ thống* 20

Hình 2 . *Use case của customer* 23

Hình 3 . *Chức năng đăng ký* 23

Hình 4 . *Chức năng đăng nhập* 24

Hình 5 . *Chức năng tìm kiếm & lọc sản phẩm* 24

Hình 6 . *Chức năng quản lí giỏ hàng* 25

Hình 7 . *Chức năng thanh toán* 26

Hình 8 . *Use case cho Admin* 27

Hình 9 . *Chức năng quản lí đơn hàng* 28

Hình 10 . *Sơ đồ ERD* 34

Hình 11 . *Cấu hình cors bảo mật không cho truy cập các miền bên ngoài* 38

Hình 12 . *Test Stored XSS* 38

Hình 13 . *Test SQL bypass login admin* 39

Hình 14 . *Test Sanitization xss của react* 39

Hình 15 . *Test stored XSS* 39

Hình 16 . *Test reflected xss* 40

Hình 17 . *Test reflected xss chức năng nhập thông tin địa chỉ* 40

Hình 18 . *Giao Giao diện đăng nhập* 41

Hình 19 . *Giao diện hồ sơ* 41

Hình 20 . *Giao diện trang chủ* 42

Hình 21 . *Giao diện tìm kiếm & filtering sản phẩm* 42

Hình 22 . *Giao diện Giỏ hàng* 43

Hình 23 . *Giao diện Dashboard Admin* 43

Hình 24 . *Giao diện Quản lý đơn hàng* 44

TÓM TẮT

Trong bối cảnh công nghệ thông tin và Internet phát triển mạnh mẽ, các hệ thống thương mại điện tử ngày càng đóng vai trò quan trọng trong hoạt động kinh doanh và đời sống xã hội. Tuy nhiên, song hành với sự phát triển đó là những rủi ro ngày càng gia tăng liên quan đến an toàn ứng dụng web và bảo mật cơ sở dữ liệu, đặc biệt đối với các website lưu trữ và xử lý nhiều thông tin nhạy cảm của người dùng.

Xuất phát từ yêu cầu thực tiễn và nội dung môn học *An toàn ứng dụng Web và Cơ sở dữ liệu*, đề tài **"Xây dựng website bán thiết bị mạng đảm bảo an toàn thông tin"** được thực hiện với mục tiêu nghiên cứu, thiết kế và xây dựng một hệ thống website thương mại điện tử đáp ứng các chức năng cơ bản, đồng thời chú trọng đến việc áp dụng các nguyên tắc và giải pháp đảm bảo an toàn cho ứng dụng web và cơ sở dữ liệu.

Trong quá trình thực hiện, đề tài tập trung nghiên cứu các lỗ hổng bảo mật phổ biến trong ứng dụng web như SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), các vấn đề liên quan đến xác thực, phân quyền người dùng và bảo mật cơ sở dữ liệu. Trên cơ sở đó, hệ thống được thiết kế và xây dựng bằng các công nghệ hiện đại như **Next.js**, **MySQL** và **Prisma ORM**, giúp nâng cao hiệu năng, khả năng quản lý dữ liệu và hạn chế các rủi ro bảo mật.

Kết quả của đề tài là một hệ thống website bán thiết bị mạng có cấu trúc rõ ràng, đáp ứng được các chức năng chính cho người dùng và quản trị viên, đồng thời đảm bảo các yêu cầu cơ bản về an toàn thông tin trong phạm vi đồ án môn học. Đề tài không chỉ giúp sinh viên củng cố kiến thức lý thuyết mà còn nâng cao kỹ năng phân tích, thiết kế và xây dựng một ứng dụng web an toàn, tạo nền tảng cho việc nghiên cứu và phát triển các hệ thống thực tế trong tương lai.

CHƯƠNG I. TỔNG QUAN

1.1. Giới thiệu đề tài

Trong bối cảnh xã hội hiện đại, công nghệ thông tin và Internet đã và đang đóng vai trò then chốt trong hầu hết các lĩnh vực của đời sống kinh tế – xã hội. Sự phát triển mạnh mẽ của các nền tảng số, cùng với hạ tầng mạng ngày càng hoàn thiện, đã tạo điều kiện thuận lợi cho các mô hình kinh doanh trực tuyến phát triển nhanh chóng, đặc biệt là lĩnh vực thương mại điện tử. Các website bán hàng trực tuyến không chỉ giúp doanh nghiệp mở rộng thị trường, tiếp cận khách hàng trên phạm vi rộng lớn mà còn mang lại sự tiện lợi cho người tiêu dùng trong quá trình tìm kiếm, so sánh và lựa chọn sản phẩm.

Ngày nay, người dùng có thể dễ dàng thực hiện các hoạt động mua sắm chỉ với một thiết bị kết nối Internet. Thông qua các website thương mại điện tử, thông tin về sản phẩm được cung cấp một cách đầy đủ và minh bạch, từ đó giúp người tiêu dùng đưa ra quyết định mua hàng nhanh chóng và hiệu quả hơn. Chính vì vậy, việc xây dựng các hệ thống web bán hàng đã trở thành xu hướng tất yếu trong thời đại số.

Tuy nhiên, song song với sự phát triển đó, vấn đề an toàn ứng dụng web và bảo mật cơ sở dữ liệu ngày càng trở nên cấp thiết. Các hệ thống web thương mại điện tử thường lưu trữ và xử lý nhiều thông tin quan trọng như dữ liệu cá nhân người dùng, thông tin tài khoản, đơn hàng, lịch sử giao dịch và các dữ liệu liên quan khác. Nếu hệ thống không được thiết kế và triển khai một cách an toàn, các dữ liệu này có thể bị khai thác trái phép, dẫn đến những hậu quả nghiêm trọng như rò rỉ thông tin, mất uy tín của doanh nghiệp hoặc thiệt hại về kinh tế.

Trong thực tế, đã có nhiều vụ tấn công mạng nhắm vào các website thương mại điện tử thông qua các lỗ hổng bảo mật phổ biến như SQL Injection, Cross-Site Scripting (XSS) hay chiếm quyền truy cập trái phép. Những rủi ro này cho thấy rằng việc xây dựng một hệ thống web không chỉ dừng lại ở việc đáp ứng các chức năng nghiệp vụ mà còn phải đảm bảo các yêu cầu nghiêm ngặt về bảo mật và an toàn dữ liệu.

Thiết bị mạng là nhóm sản phẩm giữ vai trò quan trọng trong hạ tầng công nghệ thông tin, phục vụ cho nhu cầu kết nối, truyền tải dữ liệu và đảm bảo an toàn thông tin trong các tổ chức, doanh nghiệp cũng như đối với người dùng cá nhân. Việc kinh doanh thiết bị mạng thông qua nền tảng trực tuyến đòi hỏi hệ thống phải có độ tin cậy cao, dữ liệu chính xác và cơ chế bảo mật chặt chẽ nhằm bảo vệ thông tin người dùng và hoạt động của hệ thống.

Xuất phát từ những yêu cầu thực tiễn đó, nhóm thực hiện đề tài “Xây dựng website bán thiết bị mạng an toàn” với mục tiêu nghiên cứu, thiết kế và xây dựng một hệ thống web bán hàng trực tuyến sử dụng các công nghệ hiện đại như Next.js, MySQL và Prisma,

đồng thời chú trọng đến việc áp dụng các giải pháp đảm bảo an toàn ứng dụng web và cơ sở dữ liệu.

1.2. Lý do chọn đề tài

Việc lựa chọn đề tài "Xây dựng website bán thiết bị mạng an toàn" xuất phát từ nhiều lý do cả về mặt thực tiễn lẫn học thuật.

Thứ nhất, nhu cầu mua sắm trực tuyến ngày càng gia tăng. Cùng với sự phát triển của Internet và các thiết bị di động, thói quen mua sắm của người tiêu dùng đã có sự thay đổi rõ rệt. Người dùng ngày càng ưu tiên hình thức mua sắm trực tuyến bởi sự tiện lợi, nhanh chóng và khả năng tiếp cận đa dạng các sản phẩm. Việc xây dựng một website bán thiết bị mạng giúp mô phỏng sát với nhu cầu thực tế của thị trường, đồng thời phản ánh đúng xu hướng phát triển của thương mại điện tử hiện nay.

Thứ hai, các hệ thống web thương mại điện tử tiềm ẩn nhiều rủi ro về bảo mật. Trong quá trình vận hành, website có thể trở thành mục tiêu của các cuộc tấn công mạng nếu không được thiết kế an toàn ngay từ đầu. Những lỗ hổng trong quá trình lập trình hoặc thiết kế cơ sở dữ liệu có thể dẫn đến mất mát dữ liệu, lộ thông tin người dùng hoặc gây gián đoạn hoạt động của hệ thống. Điều này đặc biệt phù hợp với nội dung môn học An toàn ứng dụng Web và Cơ sở dữ liệu, nơi sinh viên cần nắm vững các nguyên tắc bảo mật và biết cách áp dụng vào các hệ thống thực tế.

Thứ ba, sự phát triển của các công nghệ web hiện đại đã mở ra nhiều hướng tiếp cận mới trong việc xây dựng ứng dụng web. Trong đó, Next.js là một framework mạnh mẽ hỗ trợ phát triển cả frontend và backend trong cùng một hệ thống, giúp tối ưu hiệu năng và tăng cường bảo mật. Kết hợp với MySQL và Prisma ORM, hệ thống có thể quản lý dữ liệu một cách hiệu quả, an toàn và dễ mở rộng. Việc áp dụng các công nghệ này giúp sinh viên tiếp cận mô hình phát triển web hiện đại, phù hợp với yêu cầu của môi trường doanh nghiệp.

Thứ tư, đề tài giúp kết hợp chặt chẽ giữa lý thuyết và thực hành. Thông qua quá trình phân tích yêu cầu, thiết kế cơ sở dữ liệu, xây dựng chức năng và triển khai các biện pháp bảo mật, sinh viên có thể rèn luyện tư duy hệ thống, kỹ năng lập trình cũng như kỹ năng làm việc với cơ sở dữ liệu một cách toàn diện.

1.3. Mục tiêu của đề tài

Mục tiêu tổng quát của đề tài là xây dựng một website bán thiết bị mạng trực tuyến đáp ứng các yêu cầu chức năng cơ bản của một hệ thống thương mại điện tử, đồng thời đảm bảo an toàn cho ứng dụng web và cơ sở dữ liệu.

Cụ thể, đề tài hướng đến các mục tiêu sau:

- Xây dựng hệ thống website cho phép người dùng xem, tìm kiếm và mua các thiết bị mạng trực tuyến một cách thuận tiện.
- Thiết kế và quản lý cơ sở dữ liệu bằng MySQL thông qua Prisma ORM, đảm bảo tính toàn vẹn và nhất quán của dữ liệu.
- Áp dụng các nguyên tắc an toàn ứng dụng web trong quá trình phát triển hệ thống nhằm hạn chế các nguy cơ tấn công phổ biến.
- Xây dựng các chức năng xác thực và phân quyền người dùng, từ đó kiểm soát truy cập và bảo vệ dữ liệu hệ thống.
- Nâng cao khả năng bảo mật dữ liệu người dùng và dữ liệu nghiệp vụ.

Giúp sinh viên hiểu rõ quy trình xây dựng một ứng dụng web an toàn từ khâu thiết kế đến triển khai.

1.4. Phạm vi và đối tượng nghiên cứu

1.4.1. Phạm vi nghiên cứu

Đề tài tập trung nghiên cứu và xây dựng một website bán thiết bị mạng với các chức năng cơ bản của một hệ thống thương mại điện tử, bao gồm quản lý người dùng, quản lý sản phẩm, quản lý đơn hàng và quản lý dữ liệu trong cơ sở dữ liệu MySQL. Bên cạnh đó, đề tài chú trọng đến việc áp dụng các giải pháp đảm bảo an toàn cho ứng dụng web và cơ sở dữ liệu.

Do giới hạn về thời gian và phạm vi nghiên cứu, đề tài không đi sâu vào việc tích hợp các hệ thống thanh toán trực tuyến phức tạp hoặc các dịch vụ bên thứ ba nâng cao.

1.4.2. Đối tượng nghiên cứu

Đối tượng nghiên cứu của đề tài bao gồm:

- Các mô hình và kiến trúc ứng dụng web hiện đại.
- Các kỹ thuật đảm bảo an toàn ứng dụng web.
- Hệ quản trị cơ sở dữ liệu MySQL và ORM Prisma.

Framework Next.js trong phát triển frontend và backend.

1.5. Ý nghĩa của đề tài

1.5.1. Ý nghĩa thực tiễn

Đề tài mô phỏng một hệ thống bán hàng trực tuyến có khả năng áp dụng trong thực tế, giúp làm rõ quy trình xây dựng và vận hành một website thương mại điện tử an toàn.

Kết quả của đề tài có thể được sử dụng làm nền tảng để tiếp tục phát triển và mở rộng trong các dự án thực tế.

1.5.2. Ý nghĩa học thuật

Thông qua đề tài, sinh viên có cơ hội củng cố và vận dụng kiến thức về phát triển ứng dụng web, thiết kế cơ sở dữ liệu và an toàn ứng dụng web. Qua đó, nâng cao khả năng áp dụng kiến thức lý thuyết vào các bài toán thực tế.

1.6. Bố cục báo cáo

Nội dung báo cáo được trình bày gồm 4 chương chính:

- Chương I: Tổng quan đề tài – Trình bày lý do chọn đề tài, mục tiêu, phạm vi nghiên cứu và ý nghĩa của đề tài.
- Chương II: Cơ sở lý thuyết và công nghệ áp dụng – Trình bày các kiến thức nền tảng về an toàn ứng dụng web, cơ sở dữ liệu và các công nghệ sử dụng trong hệ thống.
- Chương III: Phân tích và thiết kế hệ thống – Phân tích yêu cầu, thiết kế sơ đồ và mô hình hệ thống.
- Chương IV: Kết luận và hướng phát triển – Tổng kết kết quả đạt được, nêu ra các hạn chế và đề xuất hướng phát triển trong tương lai.

CHƯƠNG II. CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ ÁP DỤNG

2.1. Tổng quan về an toàn ứng dụng web

An toàn ứng dụng web là một trong những yếu tố quan trọng hàng đầu trong quá trình xây dựng và vận hành các hệ thống thông tin hiện đại. Đặc biệt đối với các website thương mại điện tử, nơi lưu trữ và xử lý nhiều dữ liệu nhạy cảm như thông tin cá nhân người dùng, tài khoản đăng nhập, dữ liệu đơn hàng và lịch sử giao dịch, việc đảm bảo an toàn cho hệ thống là yêu cầu bắt buộc.

Một ứng dụng web an toàn cần đảm bảo ba yếu tố cốt lõi, thường được gọi là mô hình CIA:

- Tính bảo mật (Confidentiality): Dữ liệu chỉ được truy cập bởi các đối tượng hợp lệ và có quyền.
- Tính toàn vẹn (Integrity): Dữ liệu không bị thay đổi trái phép trong quá trình lưu trữ và xử lý.
- Tính sẵn sàng (Availability): Hệ thống luôn sẵn sàng phục vụ người dùng hợp lệ khi cần thiết.

Trong phạm vi đề tài này, các nguyên tắc an toàn ứng dụng web được xem xét và áp dụng xuyên suốt quá trình thiết kế và xây dựng website bán thiết bị mạng nhằm giảm thiểu rủi ro bảo mật và bảo vệ dữ liệu hệ thống.

2.2. Kiến trúc ứng dụng web hiện đại

2.2.1. Mô hình Client - Server

Hệ thống web trong đề tài được xây dựng theo mô hình Client – Server, trong đó:

- Client: Là phía người dùng, chịu trách nhiệm hiển thị giao diện và gửi yêu cầu đến server thông qua trình duyệt web.
- Server: Là phía xử lý nghiệp vụ và dữ liệu, tiếp nhận yêu cầu từ client, xử lý logic và trả kết quả về cho client.

Việc phân tách rõ ràng giữa client và server giúp hệ thống dễ bảo trì, dễ mở rộng, đồng thời tăng cường khả năng kiểm soát và bảo mật dữ liệu.

2.2.2. Mô hình Fullstack và next.js

Next.js là một framework hiện đại dựa trên React, cho phép xây dựng ứng dụng web theo mô hình fullstack. Trong hệ thống này, Next.js được sử dụng cho cả frontend và backend, mang lại nhiều lợi ích như:

- Giảm độ phức tạp khi triển khai và quản lý hệ thống.
- Đồng bộ logic xử lý và dữ liệu.
- Hỗ trợ server-side rendering giúp cải thiện hiệu suất và tăng cường bảo mật.

Next.js cung cấp nhiều cơ chế như Client Components, Server Components và API Routes, cho phép tách biệt rõ ràng giữa giao diện người dùng và xử lý nghiệp vụ phía server.

2.3. Các lỗ hỏng bảo mật phổ biến trong ứng dụng web

2.3.1. SQL Injection

SQL Injection là một trong những lỗ hổng bảo mật nghiêm trọng và phổ biến nhất trong các ứng dụng web sử dụng cơ sở dữ liệu quan hệ. Kẻ tấn công có thể chèn các đoạn mã SQL độc hại thông qua các trường nhập liệu như form đăng nhập hoặc tìm kiếm, từ đó truy xuất hoặc thay đổi dữ liệu trái phép.

Biện pháp bảo mật:

- Sử dụng ORM như Prisma để kiểm soát truy vấn.
- Kiểm tra và xác thực dữ liệu đầu vào.

Không xây dựng truy vấn SQL động từ dữ liệu người dùng.

2.3.2. Cross-Site Scripting (XSS)

XSS là lỗ hổng cho phép kẻ tấn công chèn mã độc (JavaScript) vào nội dung web, từ đó đánh cắp thông tin phiên đăng nhập hoặc thực hiện các hành vi trái phép thay mặt người dùng.

Biện pháp bảo mật:

- Lọc và mã hóa dữ liệu đầu vào và đầu ra.
- Sử dụng cơ chế render an toàn của framework.
- Hạn chế sử dụng HTML động không kiểm soát.

2.3.3. Reflected XSS

Reflected XSS (Cross Site Scripting phản chiếu) là một dạng lỗ hổng bảo mật phổ biến trong ứng dụng web, xảy ra khi dữ liệu do người dùng gửi lên (ví dụ tham số trên URL, ô tìm kiếm, form) được server phản hồi lại ngay trong trang web mà không được lọc hoặc mã hóa an toàn. Kẻ tấn công có thể chèn mã JavaScript độc hại vào dữ liệu đầu

vào, khiến trình duyệt của nạn nhân thực thi mã đó khi họ truy cập vào một liên kết được tạo sẵn.

Tác hại thường gặp là đánh cắp cookie hoặc token phiên, giả mạo thao tác người dùng, chuyển hướng sang trang lừa đảo, hoặc thay đổi nội dung hiển thị để đánh lừa người dùng.

Biện pháp bảo mật:

- Mã hóa đầu ra (output encoding) theo đúng ngữ cảnh khi hiển thị dữ liệu (HTML, thuộc tính HTML, JavaScript, URL).
- Không render trực tiếp dữ liệu người dùng vào HTML; ưu tiên template engine hoặc framework có cơ chế auto-escape.
- Kiểm tra và ràng buộc dữ liệu đầu vào (input validation) theo whitelist, giới hạn độ dài, loại ký tự.
- Dùng cookie phiên có HttpOnly, Secure, SameSite để hạn chế rủi ro bị lấy cắp phiên.
- Tránh các hàm nguy hiểm như eval hoặc cơ chế chèn HTML trực tiếp từ dữ liệu người dùng.

2.3.4. Cross-Site Request Forgery (CSRF)

CSRF là hình thức tấn công lợi dụng phiên đăng nhập hợp lệ của người dùng để gửi các yêu cầu trái phép đến server mà người dùng không hay biết.

Biện pháp bảo mật:

- Sử dụng CSRF Token.
- Kiểm tra nguồn gốc request.
- Hạn chế các request thay đổi dữ liệu thông qua phương thức GET.

2.3.5. CORS Misconfiguration

CORS Misconfiguration (cấu hình sai CORS) là lỗi bảo mật xảy ra khi website cấu hình Cross-Origin Resource Sharing quá “thoáng”, cho phép các domain khác truy cập tài nguyên hoặc API một cách không kiểm soát. Bình thường, trình duyệt chặn các request cross-origin để bảo vệ người dùng. Nhưng nếu server trả về header CORS sai (ví dụ cho phép mọi origin hoặc cho phép origin lạ kèm theo gửi cookie), attacker có thể gọi API từ một trang độc hại và đọc dữ liệu phản hồi, dẫn đến rò rỉ thông tin nhạy cảm hoặc thực hiện thao tác thay người dùng.

Lỗi này thường nguy hiểm khi API trả về dữ liệu riêng tư (thông tin cá nhân, đơn hàng, token) và hệ thống dùng cookie phiên đăng nhập.

Biện pháp bảo mật:

- Không dùng Access-Control-Allow-Origin: * cho API có dữ liệu nhạy cảm.
- Chỉ whitelist các origin tin cậy (đúng domain, đúng scheme https, đúng port nếu có).
- Không bật Access-Control-Allow-Credentials: true nếu không thật sự cần; nếu bật thì tuyệt đối không được dùng * cho Allow-Origin.
- Kiểm soát chặt Access-Control-Allow-Methods và Access-Control-Allow-Headers, chỉ cho phép cái cần thiết.
- Không phản chiếu (reflect) origin từ request một cách mù quáng (lấy Origin rồi trả lại luôn).
- Hạn chế expose header nhạy cảm, và cấu hình Vary: Origin đúng để tránh cache sai.
- Tách riêng domain cho frontend và API, áp dụng CORS theo môi trường (dev/staging/prod) và kiểm tra định kỳ cấu hình.

2.3.6. Directory Traversal Vulnerabilities

Directory Traversal (hay Path Traversal) là lỗ hổng cho phép kẻ tấn công truy cập trái phép vào các file hoặc thư mục trên server bằng cách thao túng đường dẫn file mà ứng dụng xử lý. Thường gặp ở các chức năng như: tải file (download), xem ảnh/tài liệu, đọc log, export report… Nếu ứng dụng nhận tham số đường dẫn từ người dùng và ghép trực tiếp vào đường dẫn hệ thống mà không kiểm soát, attacker có thể dùng các chuỗi như ../ để "đi lùi" ra khỏi thư mục cho phép và đọc các file nhạy cảm.

Hậu quả có thể gồm: đọc file cấu hình (.env), mã nguồn, key/credential, log chứa token, hoặc trong một số trường hợp có thể dẫn tới ghi đè file (nếu có chức năng upload/ghi file) và leo thang thành chiếm quyền.

Biện pháp bảo mật:

- Không cho người dùng truyền trực tiếp đường dẫn file; dùng ID (mã file) và map sang đường dẫn an toàn ở phía server.
- Chuẩn hóa và kiểm tra đường dẫn (canonicalize/normalize) rồi đảm bảo path cuối cùng luôn nằm trong thư mục cho phép (base directory).

- Chặn các ký tự/chuỗi nguy hiểm như ../, ..\\, ký tự null byte, và các biến thể encode (URL encode/double encode).
- Whitelist loại file được phép truy cập (đuôi file, MIME type) và giới hạn tên file hợp lệ.
- Phân quyền truy cập file theo người dùng (authorization), không chỉ dựa vào path.
- Tắt directory listing, cấu hình quyền hệ thống tối thiểu (least privilege) cho user chạy service.
- Logging và cảnh báo khi có request truy cập path bất thường hoặc lỗi 403/404 lặp lại.

2.4. Lỗ hổng bảo mật liên quan đến cơ sở dữ liệu

2.4.1. Truy cập trái phép vào cơ sở dữ liệu

Nếu hệ thống phân quyền không chặt chẽ, kẻ tấn công có thể truy cập trực tiếp vào cơ sở dữ liệu và thao túng dữ liệu.

Biện pháp bảo mật:

- Phân quyền truy cập rõ ràng theo vai trò.
- Không công khai thông tin kết nối CSDL.
- Giới hạn quyền của tài khoản database.

2.4.2. Mất toàn vẹn dữ liệu

Dữ liệu có thể bị thay đổi hoặc xóa trái phép do thiếu ràng buộc hoặc kiểm soát.

Biện pháp bảo mật:

- Sử dụng khóa chính, khóa ngoại.
- Áp dụng ràng buộc dữ liệu.
- Sao lưu dữ liệu định kỳ.

2.5. Lỗ hổng bảo mật liên quan đến Web Server

2.5.1. Cấu hình Web Server không an toàn

Cấu hình server không phù hợp có thể để lộ thông tin hệ thống hoặc tạo điều kiện cho các cuộc tấn công.

Biện pháp bảo mật:

- Ẩn thông tin phiên bản server.
- Cấu hình HTTPS.
- Giới hạn quyền truy cập thư mục.

2.5.2. Tấn công từ chối dịch vụ (DoS/DDoS)

Các cuộc tấn công DoS/DDoS có thể làm gián đoạn hoạt động của website bằng cách gửi lượng lớn request.

Biện pháp bảo mật:

- Giới hạn số request.
- Sử dụng firewall hoặc reverse proxy.
- Theo dõi và phát hiện hành vi bất thường.

2.6. Lỗ hổng từ phía người dùng

2.6.1. Mật khẩu yếu

Người dùng sử dụng mật khẩu yếu làm tăng nguy cơ bị tấn công.

Biện pháp bảo mật:

- Áp dụng chính sách mật khẩu mạnh.
- Mã hóa mật khẩu bằng thuật toán an toàn.
- Giới hạn số lần đăng nhập sai.

2.6.2. Thiếu nhận thức về bảo mật

Người dùng thiếu kiến thức bảo mật có thể vô tình tạo điều kiện cho các cuộc tấn công.

Biện pháp bảo mật:

- Hướng dẫn người dùng sử dụng hệ thống an toàn.
- Cảnh báo khi phát hiện hành vi bất thường.

2.7. Prisma ORM và an toàn dữ liệu

Prisma ORM giúp giảm thiểu rủi ro bảo mật trong quá trình thao tác với cơ sở dữ liệu thông qua cơ chế truy vấn an toàn, quản lý schema rõ ràng và kiểm soát migration.

Việc sử dụng Prisma giúp:

- Hạn chế SQL Injection.
- Đảm bảo tính nhất quán dữ liệu.
- Dễ dàng kiểm soát thay đổi cấu trúc CSDL.

2.8. Tổng kết chương

Chương này đã trình bày các cơ sở lý thuyết liên quan đến an toàn ứng dụng web, các lỗ hổng bảo mật phổ biến từ nhiều góc độ như ứng dụng web, cơ sở dữ liệu, web server và người dùng. Đồng thời, các biện pháp bảo mật tương ứng cũng được đề xuất nhằm giảm thiểu rủi ro và nâng cao mức độ an toàn cho hệ thống website bán thiết bị mạng. Đây là nền tảng quan trọng cho việc phân tích và thiết kế hệ thống trong chương tiếp theo.

CHƯƠNG III. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

3.1. Giới thiệu chương

Chương này tập trung vào việc phân tích yêu cầu và thiết kế hệ thống website bán thiết bị mạng an toàn. Trên cơ sở các kiến thức lý thuyết và công nghệ đã trình bày ở Chương II, hệ thống được phân tích từ góc độ nghiệp vụ và kỹ thuật nhằm xây dựng một kiến trúc hợp lý, dễ mở rộng và đảm bảo an toàn ứng dụng web cũng như cơ sở dữ liệu.

Các nội dung trong chương bao gồm việc xác định các tác nhân tham gia hệ thống, phân tích các chức năng nghiệp vụ chính, thiết kế cơ sở dữ liệu, mô hình lớp, sơ đồ tuần tự và kiến trúc tổng thể của hệ thống. Các sơ đồ và mô hình được trình bày trong chương đóng vai trò là nền tảng cho quá trình triển khai hệ thống ở giai đoạn sau.

3.2. Phân tích yêu cầu hệ thống

Hệ thống website bán thiết bị mạng được xây dựng nhằm đáp ứng nhu cầu mua sắm trực tuyến của người dùng, đồng thời hỗ trợ công tác quản lý và vận hành hệ thống của quản trị viên. Từ đó, các yêu cầu nghiệp vụ của hệ thống được xác định dựa trên hai nhóm đối tượng chính là người dùng và quản trị viên.

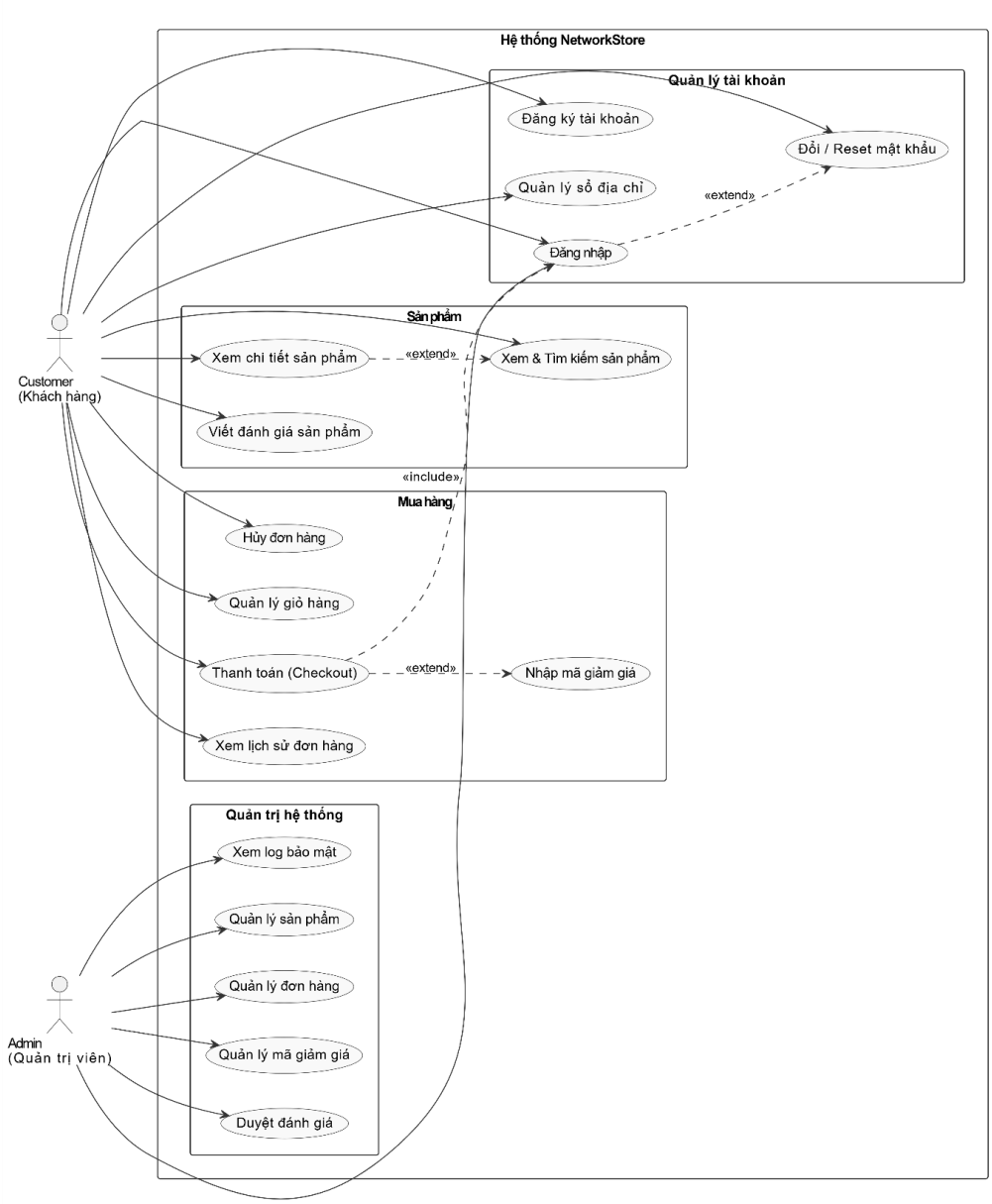
Việc phân tích yêu cầu hệ thống giúp làm rõ các chức năng cần thiết, phạm vi hoạt động và mối quan hệ giữa các thành phần trong hệ thống. Đây là bước quan trọng nhằm đảm bảo hệ thống được xây dựng đúng mục tiêu và phù hợp với yêu cầu thực tế.

3.2.1. Các tác nhân của hệ thống

Hệ thống bao gồm hai tác nhân chính:

Người dùng (User)

Quản trị viên (Admin)



Hình 1. Use Case tổng quan của hệ thống

Tác nhân Customer (Khách hàng)

Customer là người sử dụng chính của hệ thống, thực hiện các chức năng liên quan đến mua sắm và quản lý thông tin cá nhân. Các chức năng mà Customer có thể thực hiện bao gồm:

- Đăng ký tài khoản và Đăng nhập hệ thống để sử dụng đầy đủ các tính năng.
- Đổi hoặc đặt lại mật khẩu, giúp đảm bảo an toàn cho tài khoản người dùng.

- Quản lý sổ địa chỉ, phục vụ cho việc giao hàng khi mua sản phẩm.
- Xem, tìm kiếm và xem chi tiết sản phẩm, hỗ trợ người dùng tiếp cận thông tin sản phẩm trước khi quyết định mua.
- Viết đánh giá sản phẩm, giúp chia sẻ trải nghiệm và tăng tính minh bạch cho hệ thống.
- Quản lý giỏ hàng, nhập mã giảm giá và thanh toán (Checkout) để hoàn tất quá trình mua hàng.
- Xem lịch sử đơn hàng và hủy đơn hàng trong trường hợp cần thiết.

Ngoài ra, chức năng Thanh toán có quan hệ include với Đăng nhập, thể hiện rằng người dùng bắt buộc phải đăng nhập trước khi thực hiện thanh toán. Việc nhập mã giảm giá là chức năng mở rộng (extend), chỉ xảy ra khi người dùng có nhu cầu.

Tác nhân Admin (Quản trị viên)

Admin là người quản lý và vận hành hệ thống, có quyền truy cập vào các chức năng quản trị nhằm đảm bảo hệ thống hoạt động ổn định và an toàn. Các chức năng chính của Admin bao gồm:

- Quản lý sản phẩm: thêm, sửa, xóa và cập nhật thông tin các thiết bị mạng trên hệ thống.
- Quản lý đơn hàng: theo dõi, xác nhận và xử lý trạng thái đơn hàng của khách hàng.
- Quản lý mã giảm giá, phục vụ các chương trình khuyến mãi.
- Duyệt đánh giá sản phẩm, nhằm kiểm soát nội dung không phù hợp và đảm bảo chất lượng thông tin.
- Xem log bảo mật, giúp theo dõi các hoạt động bất thường, hỗ trợ phát hiện và xử lý các rủi ro an ninh.
- Đăng nhập hệ thống, là điều kiện bắt buộc trước khi thực hiện các chức năng quản trị.

Ý nghĩa của sơ đồ Use Case

Sơ đồ Use Case tổng quát giúp:

- Xác định rõ vai trò và quyền hạn của từng tác nhân trong hệ thống.
- Làm rõ phạm vi chức năng mà hệ thống NetworkStore cung cấp.

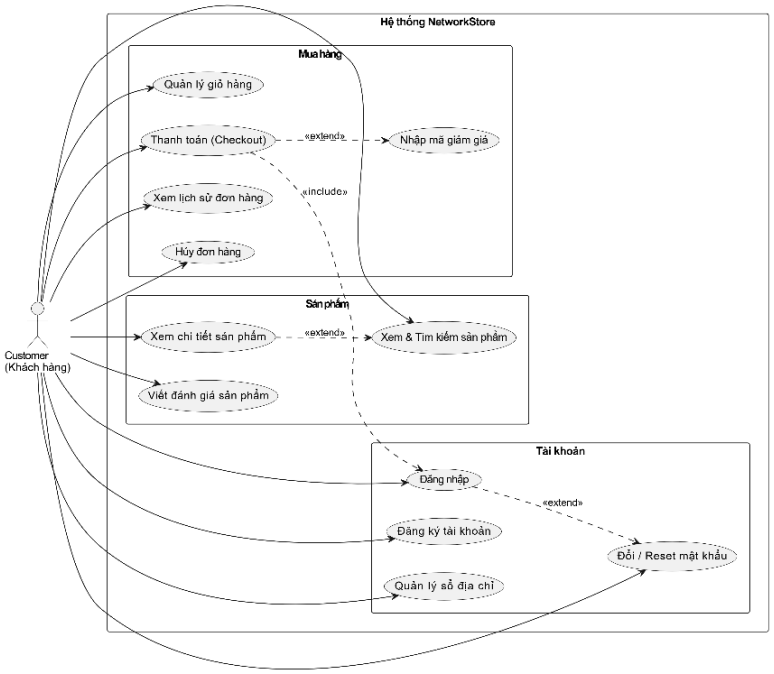
- Là cơ sở để thiết kế các sơ đồ chi tiết hơn như Use Case chi tiết, Sequence Diagram, Class Diagram và thiết kế cơ sở dữ liệu.
- Hỗ trợ phân tích các yêu cầu bảo mật, đặc biệt trong việc phân quyền giữa Customer và Admin.

3.2.2. Phân tích chức năng của người dùng

Người dùng là đối tượng trực tiếp sử dụng website để thực hiện các hoạt động mua sắm thiết bị mạng. Các chức năng chính của người dùng bao gồm:

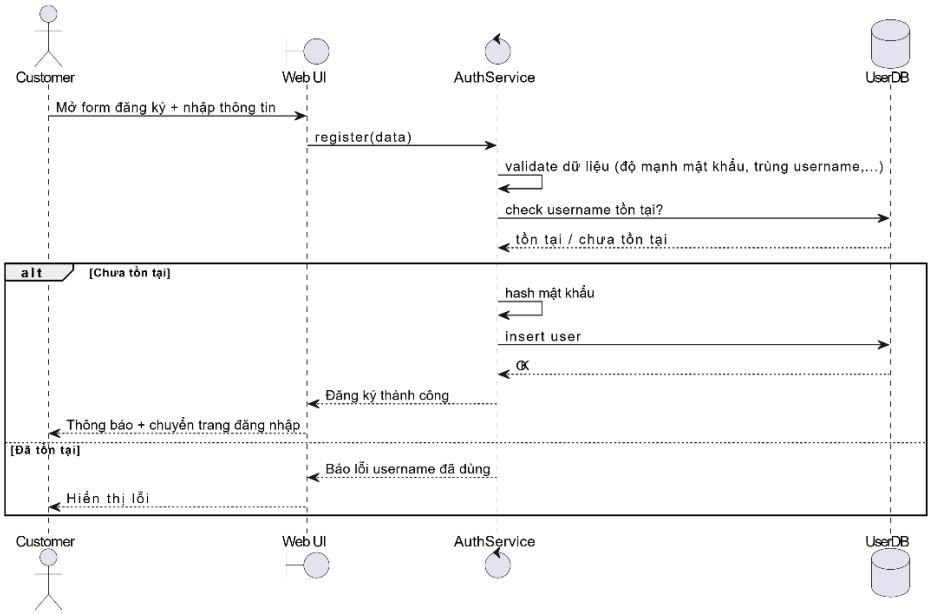
- Đăng ký,đăng nhập tài khoản & quản lí tài khoản
- Xem danh sách thiết bị mạng
- Tìm kiếm và lọc sản phẩm theo danh mục
- Xem chi tiết thông tin sản phẩm
- Thêm sản phẩm vào giỏ hàng
- Đặt hàng và theo dõi đơn hàng

Các chức năng này cần được thiết kế với giao diện thân thiện, dễ sử dụng và đảm bảo an toàn thông tin người dùng trong suốt quá trình thao tác.



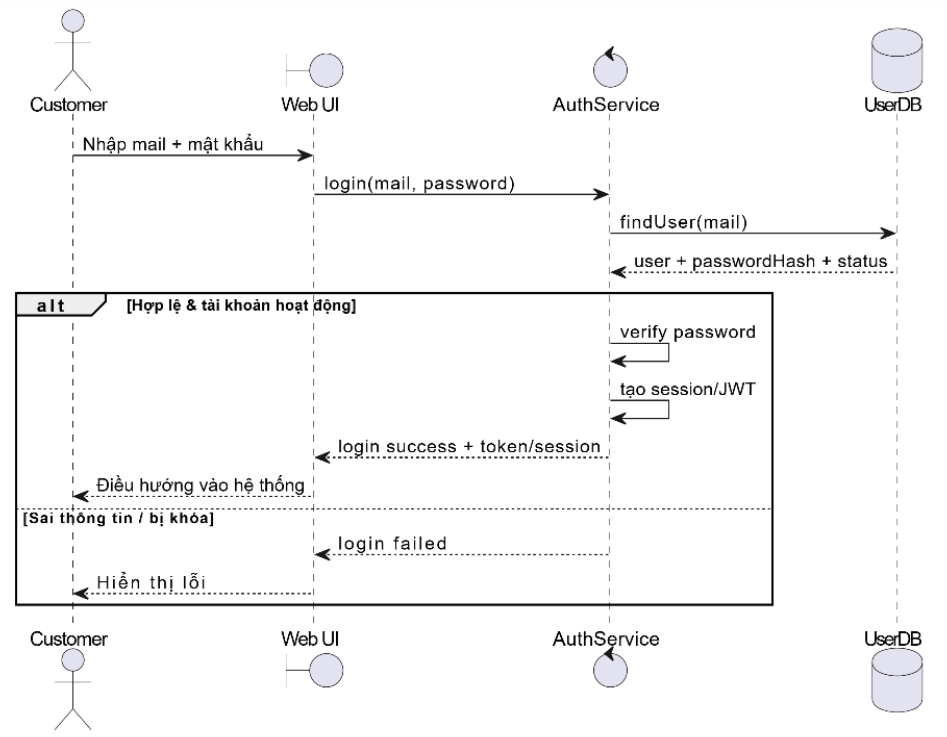
Hình 2. Use case của customer

Các sơ đồ tuần tự cho các chức năng của custommer



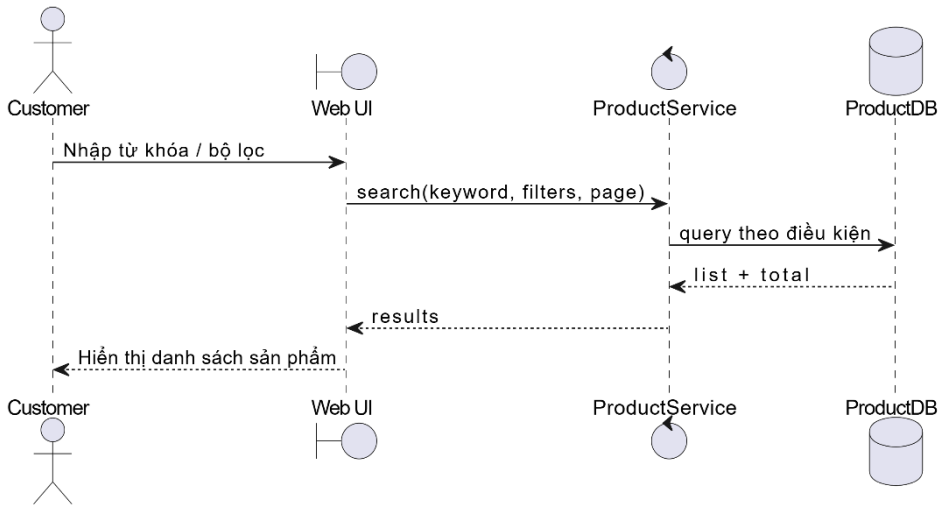
Hình 3. Chức năng đăng ký

Mô tả: Customer nhập thông tin đăng ký. Hệ thống kiểm tra hợp lệ và trùng username. Nếu hợp lệ thì băm mật khẩu và lưu vào CSDL, ngược lại trả lỗi.



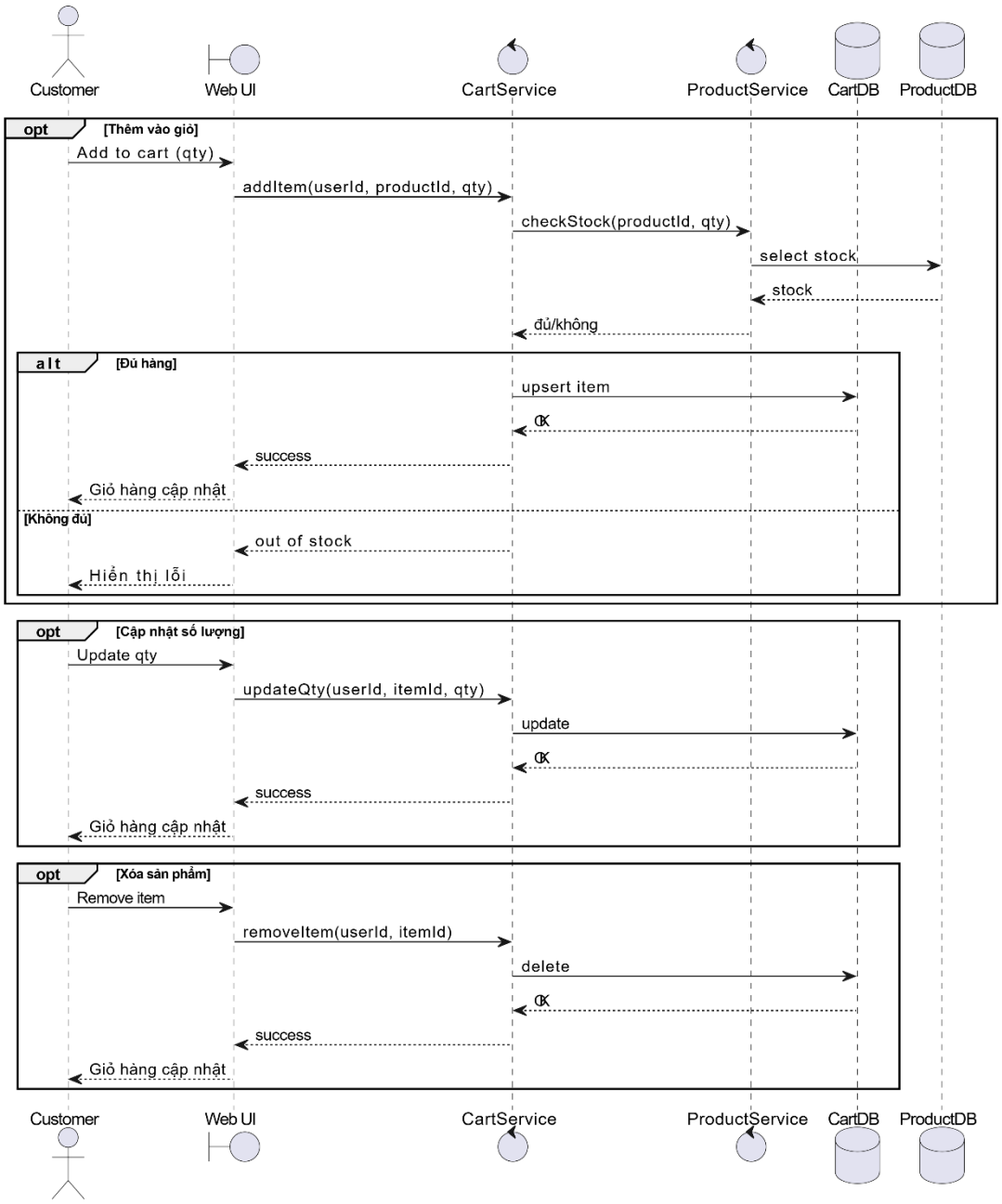
Hình 4. Chức năng đăng nhập

Mô tả: Hệ thống xác thực bằng mail/mật khẩu, tạo session/JWT khi đúng; sai thì trả thông báo lỗi.



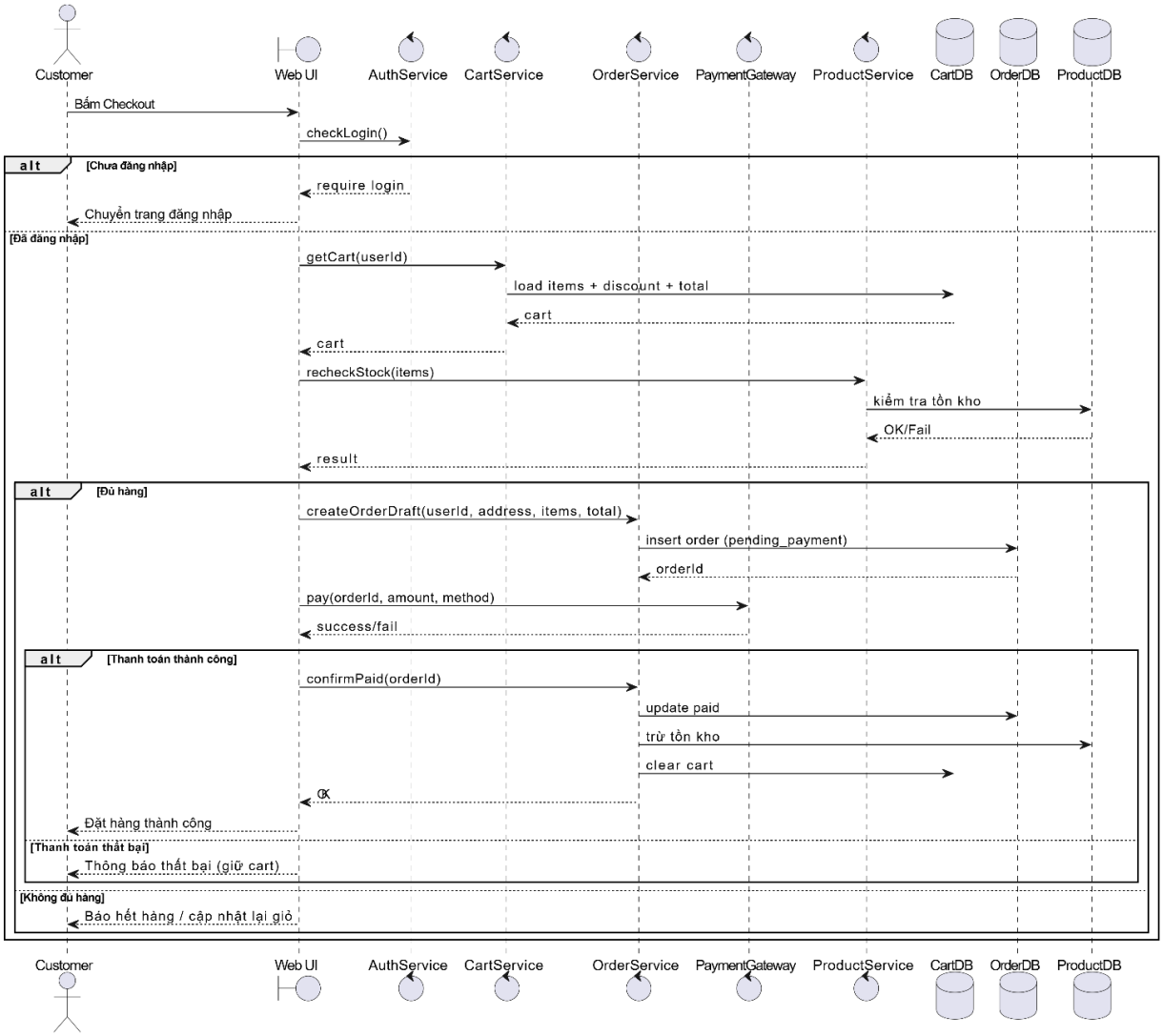
Hình 5. Chức năng tìm kiếm & lọc sản phẩm

Mô tả: UI gửi tiêu chí tìm kiếm/lọc, hệ thống truy vấn CSDL và trả danh sách theo phân trang.



Hình 6. Chức năng quản lí giỏ hàng

Mô tả: Giỏ hàng kiểm tra tồn kho khi thêm. Cập nhật/xóa tác động trên dữ liệu giỏ theo userId.



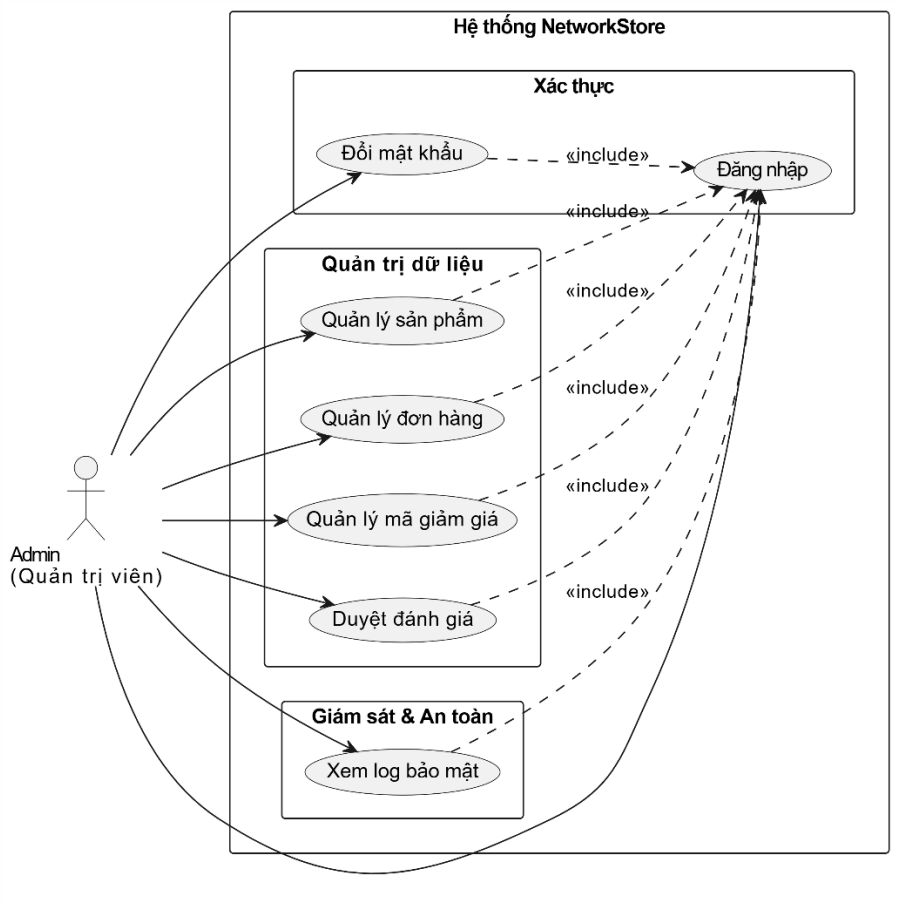
Hình 7. Chức năng thanh toán

Mô tả ngắn: Customer checkout → hệ thống kiểm tra đăng nhập → tạo đơn trạng thái chờ thanh toán → gọi cổng thanh toán → cập nhật trạng thái paid hoặc payment_failed và trả kết quả cho người dùng.

3.2.3. Phân tích chức năng của quản trị viên

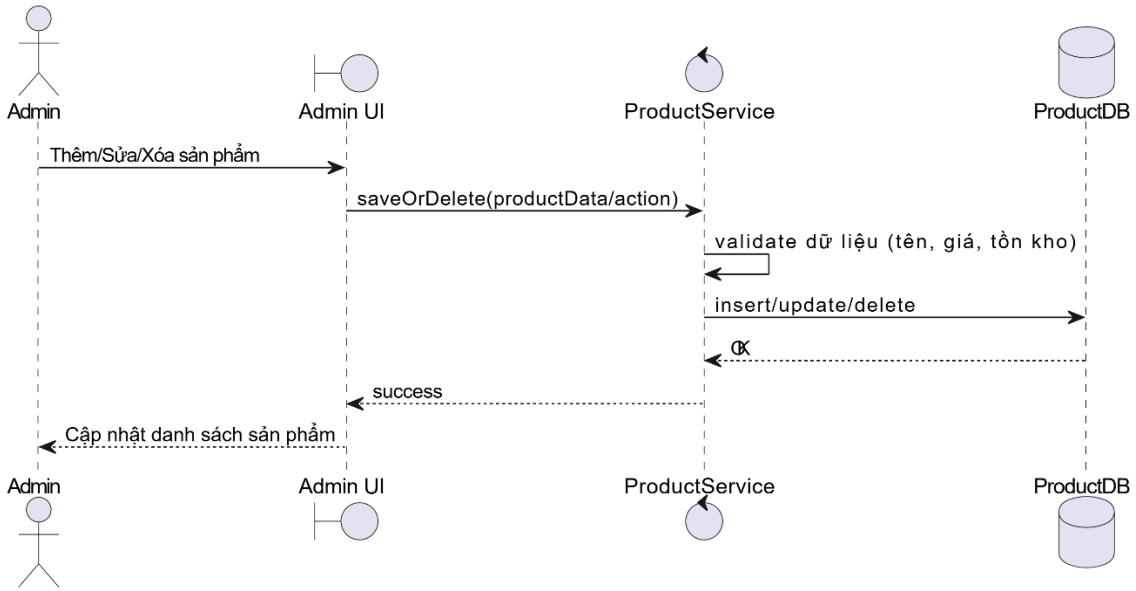
Quản trị viên là người chịu trách nhiệm quản lý và vận hành hệ thống. Các chức năng chính của quản trị viên bao gồm:

- Quản lý thông tin người dùng
- Quản lý sản phẩm thiết bị mạng
- Quản lý danh mục sản phẩm
- Quản lý đơn hàng



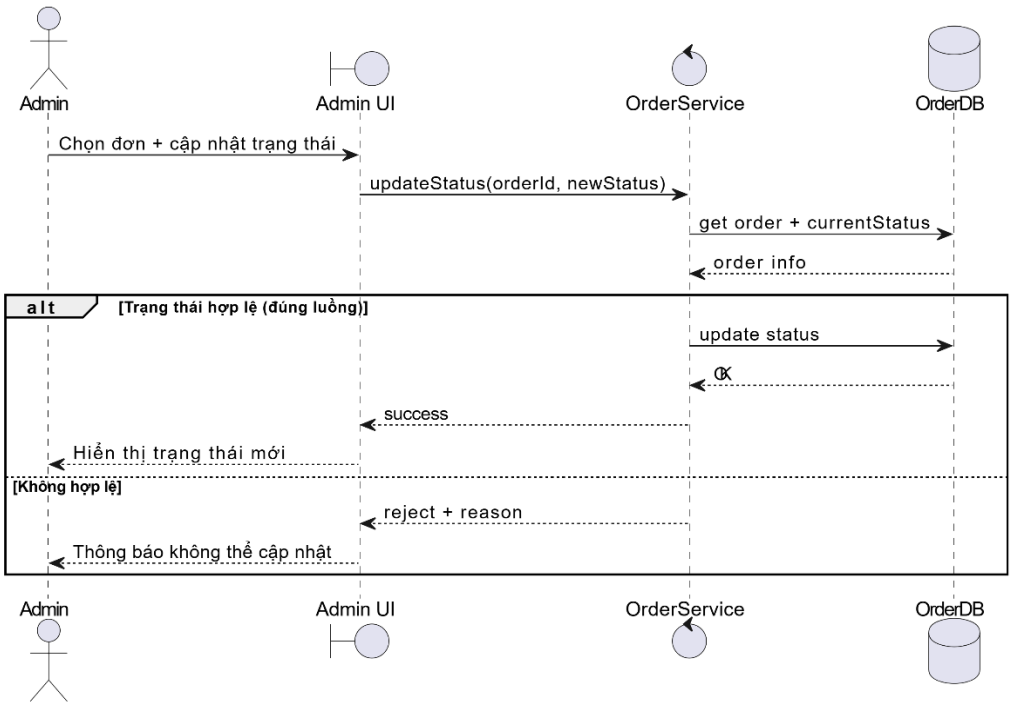
Hình 8. Use case cho Admin

Sơ đồ tuần tự cho các chức năng của Admin



Hình 9. Chức năng CRUD

Mô tả: Admin thao tác CRUD sản phẩm. Hệ thống kiểm tra dữ liệu hợp lệ rồi cập nhật vào CSDL và phản hồi kết quả.



Hình 9. Chức năng quản lí đơn hàng

Mô tả: Admin cập nhật trạng thái đơn hàng theo luồng xử lý (ví dụ: pending → processing → shipping → delivered). Nếu sai luồng thì hệ thống từ chối.

3.3. Thiết kế cơ sở dữ liệu

Dựa trên các yêu cầu nghiệp vụ đã phân tích, cơ sở dữ liệu của hệ thống được thiết kế theo mô hình cơ sở dữ liệu quan hệ. MySQL được sử dụng làm hệ quản trị cơ sở dữ liệu, kết hợp với Prisma ORM để quản lý schema và thao tác dữ liệu.

Thiết kế cơ sở dữ liệu cần đảm bảo các yêu cầu về tính toàn vẹn, nhất quán và an toàn dữ liệu.

3.3.1. Các bảng dữ liệu chính

Cơ sở dữ liệu của hệ thống website bán thiết bị mạng được thiết kế theo mô hình quan hệ, tập trung vào 4 nhóm nghiệp vụ chính: (1) người dùng & xác thực, (2) danh mục & sản phẩm, (3) giỏ hàng & đơn hàng, và (4) khuyến mãi & đánh giá. Các bảng dữ liệu chính được mô tả như sau:

Nhóm người dùng & xác thực (Authentication & Security)

1) Bảng users (Người dùng)

Là bảng trung tâm của hệ thống, lưu thông tin cơ bản của người dùng.

- Thuộc tính chính:
  id (PK), full_name, email, phone, password_hash, role, is_active, created_at
- Ý nghĩa:
  - password_hash lưu mật khẩu dưới dạng băm (không lưu plaintext).
  - role thể hiện phân quyền (ví dụ: customer/admin).
  - is_active hỗ trợ khóa/mở tài khoản.

2) Bảng user_sessions (Phiên đăng nhập)

Quản lý phiên đăng nhập để kiểm soát truy cập.

- Thuộc tính chính:
  id (PK), user_id (FK → users.id), token_hash, ip_address, expires_at, created_at
- Ý nghĩa:
  - token_hash lưu token theo dạng băm để giảm rủi ro bị lộ session.
  - expires_at hỗ trợ hết hạn phiên, tăng an toàn.

3) Bảng oauth_accounts (Liên kết đăng nhập bên thứ ba)

Lưu thông tin tài khoản đăng nhập qua nhà cung cấp OAuth (Google, Facebook, …).

- Thuộc tính chính:
  id (PK), user_id (FK), provider, provider_user_id, provider_email, is_primary
- Ý nghĩa:
  - Cho phép một user có thể liên kết nhiều provider.
  - is_primary hỗ trợ chọn tài khoản liên kết chính.

4) Bảng verification_tokens (Token xác minh/khôi phục)

Lưu token phục vụ xác minh hoặc thao tác bảo mật (quên mật khẩu, xác nhận tài khoản…).

- Thuộc tính chính:
  id (PK), user_id (FK), token_hash, token_type, expires_at, created_at
- Ý nghĩa:
  - Token lưu dạng hash.
  - token_type phân biệt mục đích sử dụng.

5) Bảng password_history (Lịch sử mật khẩu)

Lưu lịch sử các mật khẩu đã dùng để hỗ trợ chính sách "không dùng lại mật khẩu cũ".

- Thuộc tính chính:
  id (PK), user_id (FK), password_hash, created_at

6) Bảng security_logs (Nhật ký bảo mật)

Ghi nhận các sự kiện liên quan đến bảo mật để giám sát và truy vết.

- Thuộc tính chính:
  id (PK), user_id (FK), event_type, ip_address, details, created_at
- Ý nghĩa:
  - Ghi log đăng nhập thất bại, đổi mật khẩu, thao tác quan trọng,…

7) Bảng addresses (Sổ địa chỉ)

Quản lý địa chỉ giao hàng cho người dùng.

- Thuộc tính chính:
  id (PK), user_id (FK), recipient_name, phone, address_line, city, district, ward, is_default, created_at
- Ý nghĩa:
  - Một user có thể có nhiều địa chỉ.
  - is_default xác định địa chỉ mặc định.

Nhóm sản phẩm & danh mục (Catalog)

8) Bảng categories (Danh mục sản phẩm)

Phân loại thiết bị mạng theo nhóm (Router, Switch, Modem…).

- Thuộc tính chính:
  id (PK), parent_id (FK tự tham chiếu), name, slug, is_active
- Ý nghĩa:
  - parent_id giúp tạo danh mục nhiều cấp (cha–con).
  - slug phục vụ SEO và URL thân thiện.

9) Bảng products (Sản phẩm)

Lưu thông tin thiết bị mạng được bán trên hệ thống.

- Thuộc tính chính:
  id (PK), category_id (FK → categories.id), name, slug, sku, price, stock_quantity, is_active, created_at
- Ý nghĩa:
  - sku mã sản phẩm giúp quản lý kho.
  - stock_quantity hỗ trợ kiểm soát tồn kho.

10) Bảng product_images (Ảnh sản phẩm)

Quản lý hình ảnh minh họa sản phẩm.

- Thuộc tính chính:
  id (PK), product_id (FK → products.id), image_url, display_order
- Ý nghĩa:
  - Một sản phẩm có thể có nhiều ảnh.
  - display_order sắp xếp thứ tự hiển thị.

Nhóm giỏ hàng & đơn hàng (Cart & Order)

11) Bảng shopping_carts (Giỏ hàng)

Lưu "giỏ hàng" của người dùng (hoặc giỏ theo phiên).

- Thuộc tính chính:
  id (PK), user_id (FK), session_id, created_at
- Ý nghĩa:
  - Có thể hỗ trợ cả người dùng chưa đăng nhập thông qua session_id.

12) Bảng cart_items (Chi tiết giỏ hàng)

Lưu danh sách sản phẩm nằm trong giỏ.

- Thuộc tính chính:
  id (PK), cart_id (FK → shopping_carts.id), product_id (FK → products.id), quantity, added_at
- Ý nghĩa:
  - Một giỏ có nhiều dòng sản phẩm.
  - quantity là số lượng từng sản phẩm.

13) Bảng orders (Đơn hàng)

Lưu thông tin tổng quát của đơn hàng.

- Thuộc tính chính:
  id (PK), order_number, user_id (FK), status_id (FK → order_statuses.id), shipping_address_id (FK → addresses.id), billing_address_id (FK → addresses.id),
  payment_status, subtotal, shipping_fee, discount_amount, total_amount, created_at
- Ý nghĩa:
  - order_number là mã đơn hiển thị cho người dùng.
  - status_id quản lý trạng thái đơn hàng theo bảng riêng.
  - subtotal, shipping_fee, discount_amount, total_amount phục vụ tính toán minh bạch.

14) Bảng order_items (Chi tiết đơn hàng)

Lưu danh sách sản phẩm thuộc một đơn hàng (giống "OrderDetails").

- Thuộc tính chính:
  id (PK), order_id (FK → orders.id), product_id (FK → products.id), product_name, product_sku, quantity, unit_price, subtotal
- Ý nghĩa:
  - Lưu thêm product_name, product_sku để "đóng băng thông tin" tại thời điểm mua (tránh thay đổi tên/sku làm sai lịch sử).

15) Bảng order_statuses (Trạng thái đơn hàng)

Danh mục trạng thái đơn (Pending, Processing, Shipped, Completed, Cancelled…).

- Thuộc tính chính:
  id (PK), name, display_order
- Ý nghĩa:
  - Tách trạng thái ra bảng riêng giúp dễ quản trị và chuẩn hóa dữ liệu.

16) Bảng order_history (Lịch sử trạng thái đơn hàng)

Theo dõi quá trình thay đổi trạng thái của đơn.

- Thuộc tính chính:
  id (PK), order_id (FK), status_id (FK), changed_by (FK → users.id), note, created_at
- Ý nghĩa:
  - Hỗ trợ audit: ai đổi trạng thái, đổi lúc nào, lý do.

Nhóm khuyến mãi & đánh giá (Promotion & Reviews)

17) Bảng discount_codes (Mã giảm giá)

Lưu các mã giảm giá được phát hành.

- Thuộc tính chính:
  id (PK), code, discount_type, discount_value, starts_at, ends_at, is_active
- Ý nghĩa:
  - discount_type có thể là phần trăm hoặc số tiền cố định.
  - Thời gian hiệu lực quản lý bằng starts_at, ends_at.

18) Bảng discount_usage (Lịch sử sử dụng mã giảm giá)

Lưu lịch sử áp dụng mã giảm giá theo user/đơn.

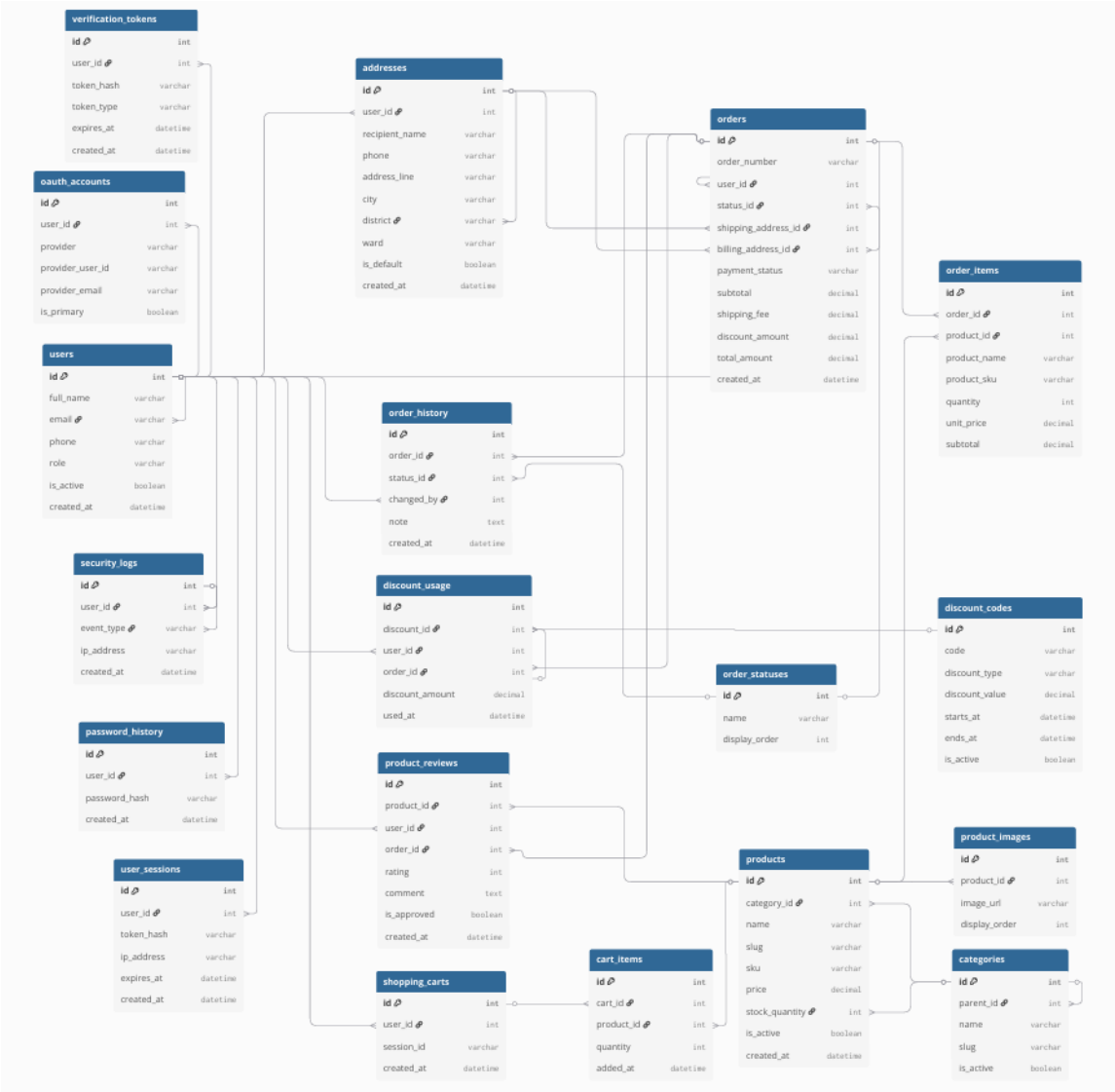
- Thuộc tính chính:
  id (PK), discount_id (FK → discount_codes.id), user_id (FK), order_id (FK), discount_amount, used_at
- Ý nghĩa:

- Giúp kiểm soát một mã dùng bao nhiêu lần và dùng cho đơn nào.

19) Bảng product_reviews (Đánh giá sản phẩm)

Cho phép người dùng đánh giá sản phẩm đã mua.

- Thuộc tính chính:
  id (PK), product_id (FK), user_id (FK), order_id (FK), rating, comment, is_approved, created_at
- Ý nghĩa:
  - is_approved hỗ trợ duyệt nội dung đánh giá trước khi hiển thị.



Hình 10. Sơ đồ ERD

Sơ đồ ERD thể hiện cấu trúc tổng thể của cơ sở dữ liệu và các mối quan hệ giữa các thực thể trong hệ thống website bán thiết bị mạng. Trung tâm của hệ thống là bảng users, liên kết với các bảng phục vụ xác thực và bảo mật như user_sessions, oauth_accounts, verification_tokens, password_history, security_logs; đồng thời liên kết với nghiệp vụ mua hàng thông qua shopping_carts, orders, order_history và product_reviews.

Ở nhánh nghiệp vụ sản phẩm, bảng products liên kết với categories theo quan hệ 1–n (một danh mục có nhiều sản phẩm) và liên kết với product_images theo quan hệ 1–n (một sản phẩm có nhiều ảnh). Quy trình đặt hàng được chuẩn hóa bởi orders (thông tin đơn tổng) và order_items (chi tiết sản phẩm trong đơn), giúp dữ liệu nhất quán và dễ truy vết. Ngoài ra, các bảng discount_codes và discount_usage cho phép quản lý chương trình giảm giá và lịch sử sử dụng mã, đảm bảo minh bạch trong tính toán tổng tiền.

Nhìn chung, sơ đồ ERD cho thấy hệ thống được thiết kế theo hướng chuẩn hóa, phân tách rõ nghiệp vụ và hỗ trợ tốt cho yêu cầu an toàn dữ liệu, toàn vẹn quan hệ, và theo dõi lịch sử thao tác trong môi trường thương mại điện tử.

3.4. Nhận xét chương

Chương này đã trình bày quá trình phân tích và thiết kế hệ thống website bán thiết bị mạng an toàn. Các nội dung phân tích và thiết kế là cơ sở quan trọng cho việc triển khai hệ thống, đồng thời giúp đảm bảo hệ thống có cấu trúc rõ ràng, dễ mở rộng và đáp ứng các yêu cầu về an toàn ứng dụng web và cơ sở dữ liệu.

CHƯƠNG IV. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1. Giới thiệu chương

Sau khi hoàn thành quá trình nghiên cứu cơ sở lý thuyết, phân tích yêu cầu và thiết kế hệ thống website bán thiết bị mạng đảm bảo an toàn thông tin, việc tổng kết và đánh giá lại toàn bộ đề tài là bước cần thiết nhằm nhìn nhận một cách khách quan mức độ hoàn thành của đồ án.

Chương này tập trung đánh giá các kết quả đạt được của hệ thống dưới nhiều góc độ khác nhau, bao gồm: mức độ đáp ứng chức năng nghiệp vụ, tính hợp lý trong thiết kế cơ sở dữ liệu, các yếu tố an toàn ứng dụng web, cũng như tính trực quan và khả năng sử dụng của giao diện người dùng. Đồng thời, chương cũng chỉ ra những hạn chế còn tồn tại do phạm vi môn học và đề xuất các hướng phát triển nhằm hoàn thiện hệ thống trong tương lai.

Ngoài ra, để tăng tính trực quan cho báo cáo, chương này cũng dành một phần nội dung để mô tả giao diện người dùng (Customer) và giao diện quản trị (Admin), giúp minh họa rõ hơn cách hệ thống được triển khai và vận hành trong thực tế.

4.2. Kết luận chung về đề tài

Trong khuôn khổ đồ án môn học An toàn ứng dụng Web và cơ sở dữ liệu, nhóm đã tiến hành xây dựng một website thương mại điện tử chuyên kinh doanh thiết bị mạng với định hướng đảm bảo an toàn thông tin ngay từ giai đoạn thiết kế. Đề tài không chỉ tập trung vào việc xây dựng các chức năng mua bán cơ bản mà còn chú trọng đến việc hạn chế các rủi ro bảo mật thường gặp trong các ứng dụng web hiện nay.

Quá trình thực hiện đề tài giúp nhóm tiếp cận một cách toàn diện quy trình phát triển một ứng dụng web, bắt đầu từ việc phân tích bối cảnh thực tế, xác định yêu cầu hệ thống, nghiên cứu các nguy cơ mất an toàn thông tin, cho đến việc đề xuất và áp dụng các giải pháp bảo mật phù hợp. Việc lựa chọn các công nghệ web hiện đại giúp hệ thống có cấu trúc rõ ràng, dễ quản lý và thuận lợi cho việc mở rộng trong tương lai.

Bên cạnh đó, đề tài còn giúp nhóm nhận thức rõ vai trò của an toàn thông tin trong các hệ thống thương mại điện tử, đặc biệt là những hệ thống xử lý dữ liệu nhạy cảm như thông tin tài khoản, đơn hàng và lịch sử giao dịch. Việc xây dựng hệ thống theo hướng an toàn ngay từ đầu giúp giảm thiểu rủi ro phát sinh trong quá trình vận hành và nâng cao độ tin cậy của website.

4.3. Đánh giá kết quả đạt được

4.3.1. Đánh giá về mặt chức năng hệ thống

Hệ thống website bán thiết bị mạng đã đáp ứng được các chức năng cơ bản cần thiết của một hệ thống thương mại điện tử, phục vụ hai nhóm đối tượng chính là người dùng (Customer) và quản trị viên (Admin).

Đối với người dùng, hệ thống cho phép thực hiện đầy đủ các thao tác trong quy trình mua hàng trực tuyến, từ việc xem danh sách sản phẩm, tìm kiếm và lọc thiết bị mạng theo danh mục, xem chi tiết thông tin sản phẩm, cho đến việc thêm sản phẩm vào giỏ hàng và tạo đơn đặt hàng. Các chức năng này được thiết kế theo hướng đơn giản, dễ sử dụng, giúp người dùng dễ dàng tiếp cận và thao tác ngay cả khi không có nhiều kinh nghiệm sử dụng website thương mại điện tử.
Đối với quản trị viên, hệ thống cung cấp các chức năng quản lý cần thiết để vận hành website, bao gồm quản lý sản phẩm, quản lý danh mục, quản lý đơn hàng và kiểm soát dữ liệu hệ thống. Việc tách biệt rõ ràng chức năng của người dùng và quản trị viên giúp hạn chế rủi ro truy cập trái phép vào các khu vực nhạy cảm của hệ thống.
Nhìn chung, các chức năng của hệ thống đã đáp ứng đúng mục tiêu của đề tài trong phạm vi đồ án môn học. Tuy nhiên, để triển khai trong môi trường thực tế, hệ thống vẫn cần bổ sung thêm nhiều chức năng nâng cao nhằm tăng tính tiện lợi và khả năng mở rộng.

4.3.2. Đánh giá về mặt thiết kế cơ sở dữ liệu

Cơ sở dữ liệu của hệ thống được thiết kế theo mô hình quan hệ, đảm bảo sự liên kết chặt chẽ giữa các bảng dữ liệu thông qua khóa chính và khóa ngoại. Các bảng dữ liệu cốt lõi như Users, Products, Categories, Orders và OrderDetails được xây dựng phù hợp với các yêu cầu nghiệp vụ của hệ thống.
Thiết kế này giúp đảm bảo:

- Tính toàn vẹn dữ liệu, tránh tình trạng dữ liệu mồ côi hoặc không nhất quán.
- Tính nhất quán, đặc biệt trong quá trình xử lý đơn hàng và quản lý sản phẩm.
- Khả năng mở rộng, cho phép bổ sung thêm các bảng và chức năng mới trong tương lai mà không ảnh hưởng đến cấu trúc hiện tại.

Bên cạnh đó, việc kết hợp MySQL với ORM giúp quá trình thao tác dữ liệu trở nên an toàn hơn, giảm thiểu rủi ro từ các truy vấn không kiểm soát, đồng thời hỗ trợ quản lý schema và migration một cách hiệu quả.

4.3.3. Đánh giá về mặt an toàn ứng dụng web

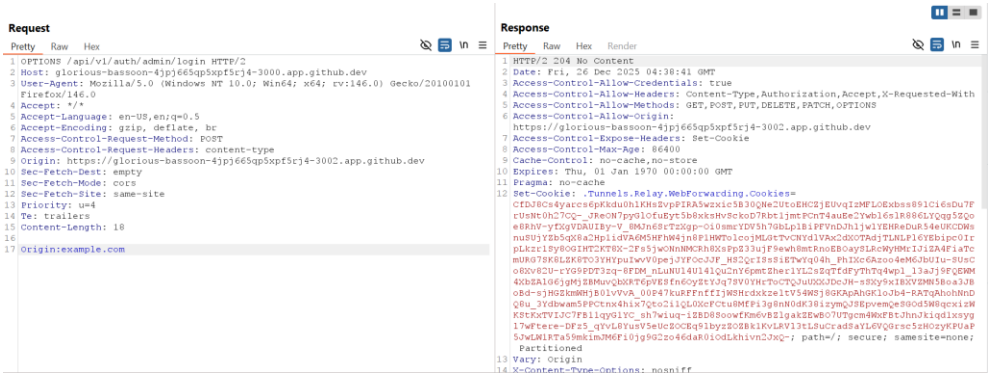
Một trong những mục tiêu quan trọng của đề tài là đảm bảo an toàn ứng dụng web và cơ sở dữ liệu. Trong quá trình xây dựng hệ thống, nhóm đã chú trọng đến một số nguyên tắc bảo mật cơ bản như:

- Xác thực người dùng trước khi truy cập các chức năng quan trọng.
- Phân quyền rõ ràng giữa người dùng và quản trị viên.
- Kiểm soát dữ liệu đầu vào nhằm hạn chế các lỗ hổng phổ biến như SQL Injection và XSS.
- Hạn chế truy cập trực tiếp vào cơ sở dữ liệu từ phía client.

Mặc dù các biện pháp bảo mật được triển khai chủ yếu ở mức cơ bản, nhưng chúng đã góp phần nâng cao mức độ an toàn của hệ thống và phù hợp với phạm vi của đồ án môn học.

Kiểm thử hệ thống

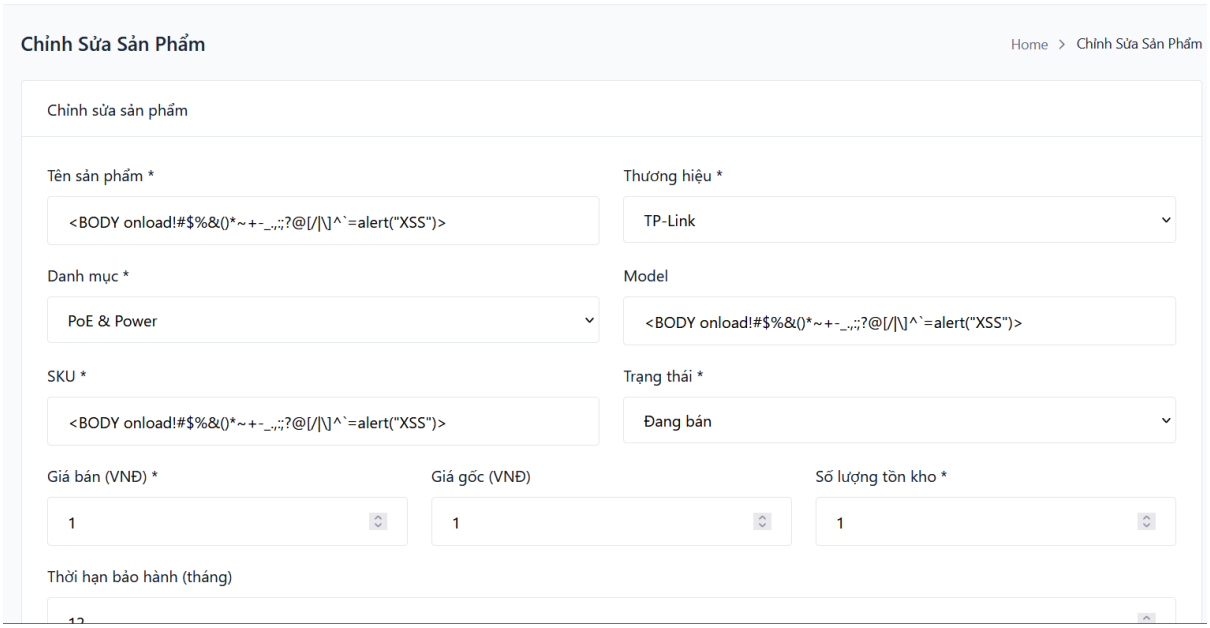
Về Admin:



Hình 11. Cấu hình cors bảo mật không cho truy cập các miền bên ngoài



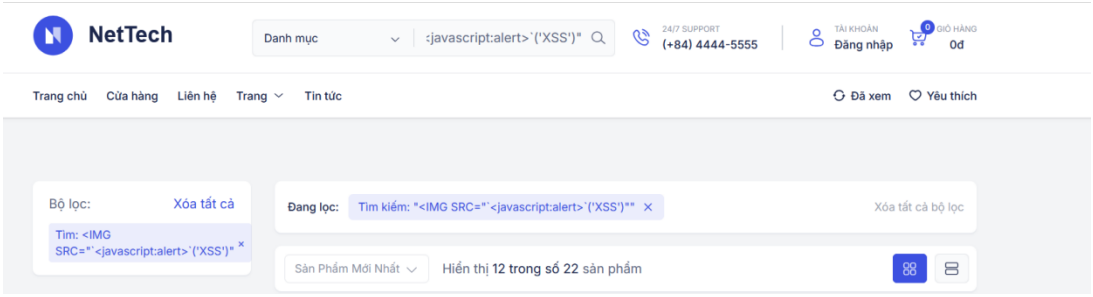
Hình 12. Test Stored XSS



Hình 13. Test SQL bypass login admin

Về Custommer:

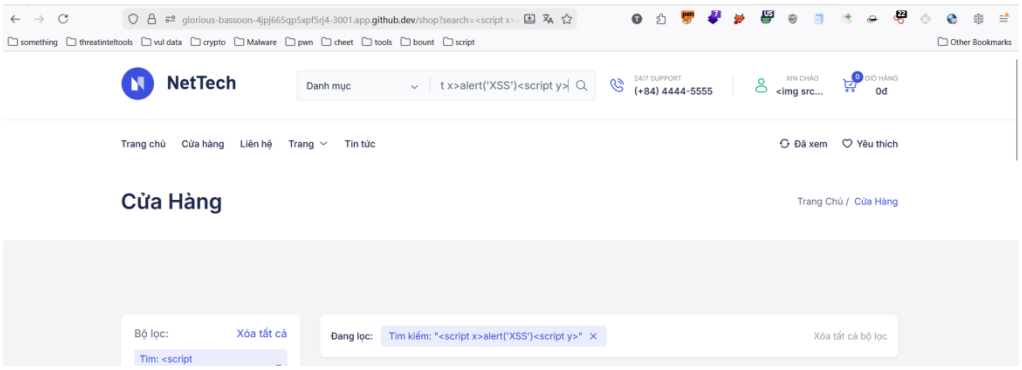
- Sử dụng nuclei để kiểm tra các lỗ hổng phổ biến ở phía custommer & sử dụng XSStrike.py để test tự động



Hình 14. Test Sanitization xss của react



Hình 15. Test stored XSS



Hình 16. Test reflected xss



Hình 17. Test reflected xss chức năng nhập thông tin địa chỉ

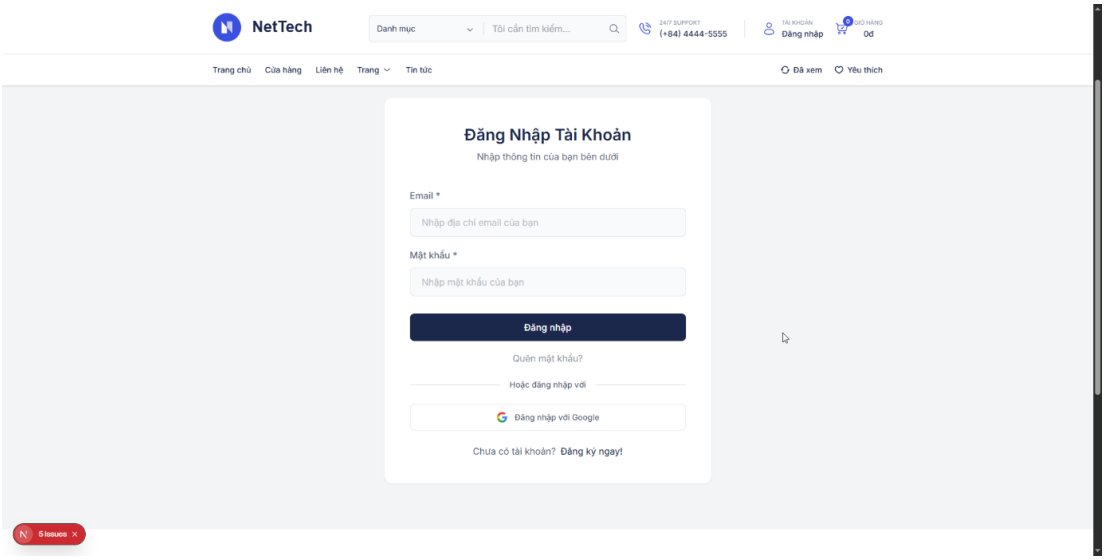
Đánh giá giao diện người dùng (GUI)

4.4.1. Giao diện người dùng (Customer)

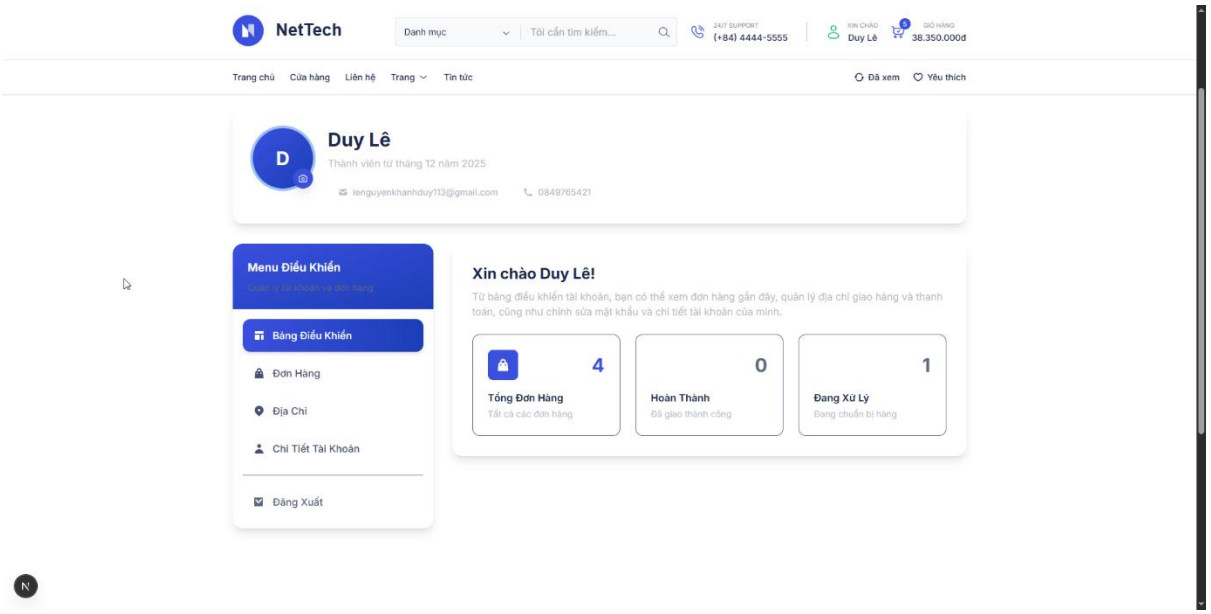
Giao diện người dùng được thiết kế theo hướng trực quan, tập trung vào trải nghiệm mua sắm thiết bị mạng. Các thành phần giao diện được bố trí hợp lý, giúp người dùng dễ dàng tìm kiếm thông tin sản phẩm và thực hiện các thao tác cần thiết.

Giao diện trang chủ và danh sách sản phẩm cho phép hiển thị rõ ràng các thiết bị mạng theo danh mục, kết hợp với chức năng tìm kiếm giúp người dùng nhanh chóng tiếp cận sản phẩm mong muốn. Trang chi tiết sản phẩm cung cấp đầy đủ thông tin về thiết bị, hỗ trợ người dùng đưa ra quyết định mua hàng chính xác hơn.

Giao diện Customer



Hình 18. Giao Giao diện đăng nhập



Hình 19. Giao diện hồ sơ

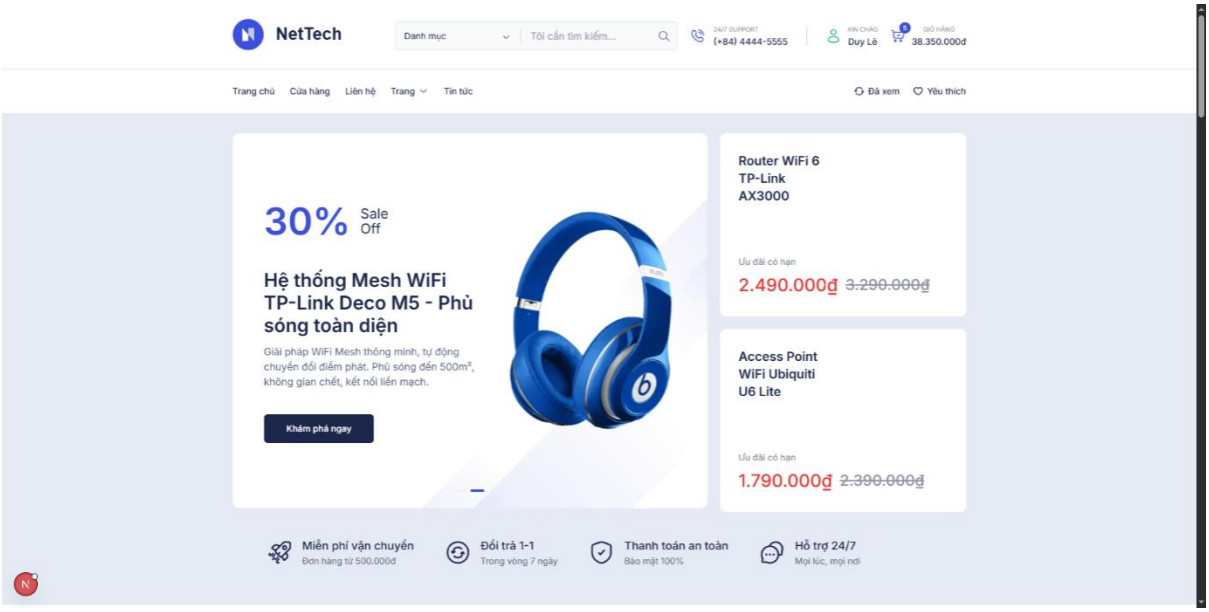
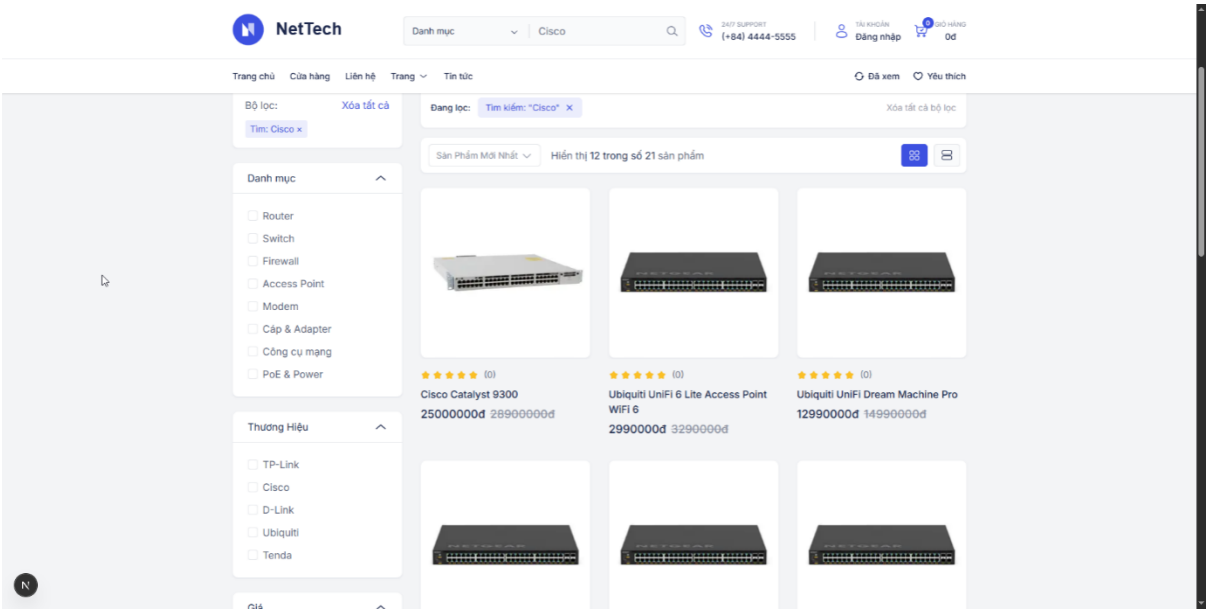
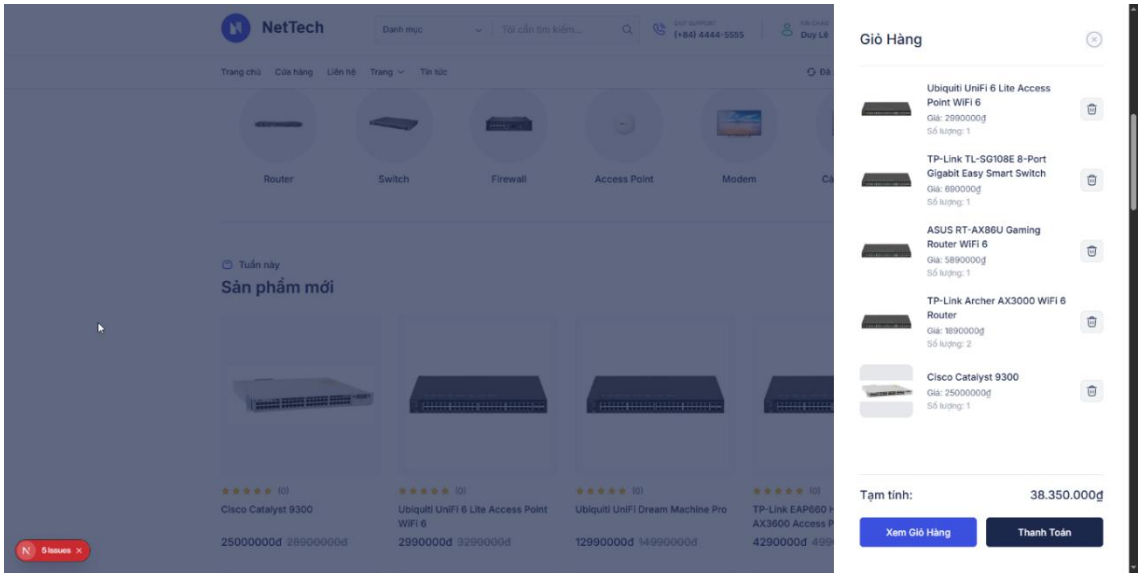


Table 20. Giao diện trang chủ



Hình 21. Giao diện tìm kiếm & filtering sản phẩm

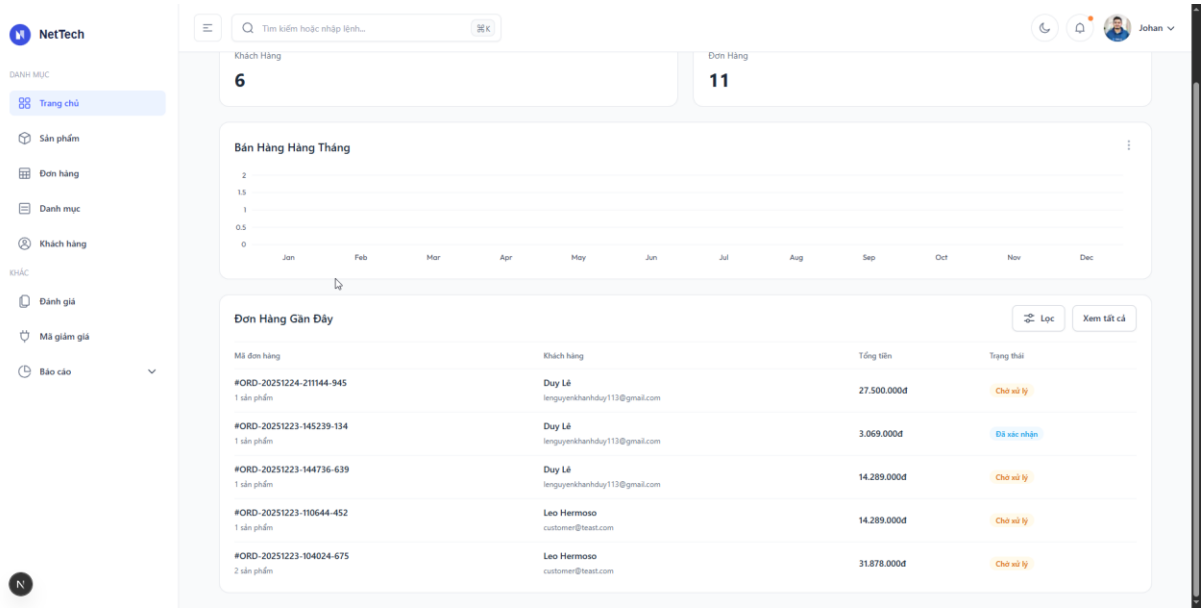


Hình 22. Giao diện Giỏ hàng

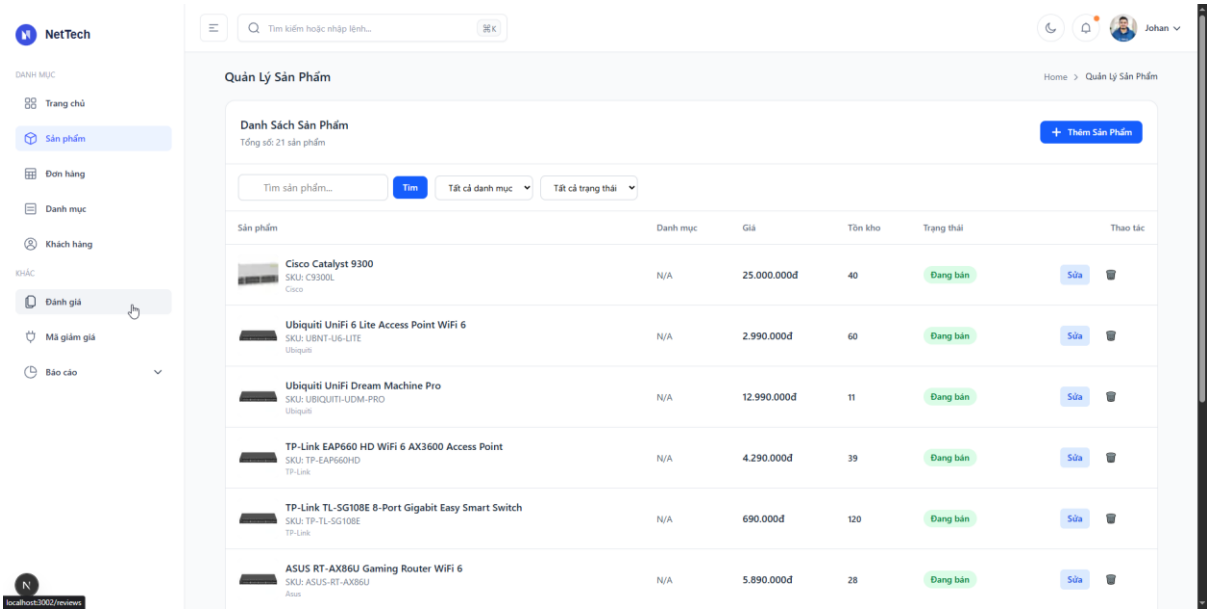
4.4.2. Giao diện quản trị (Admin)

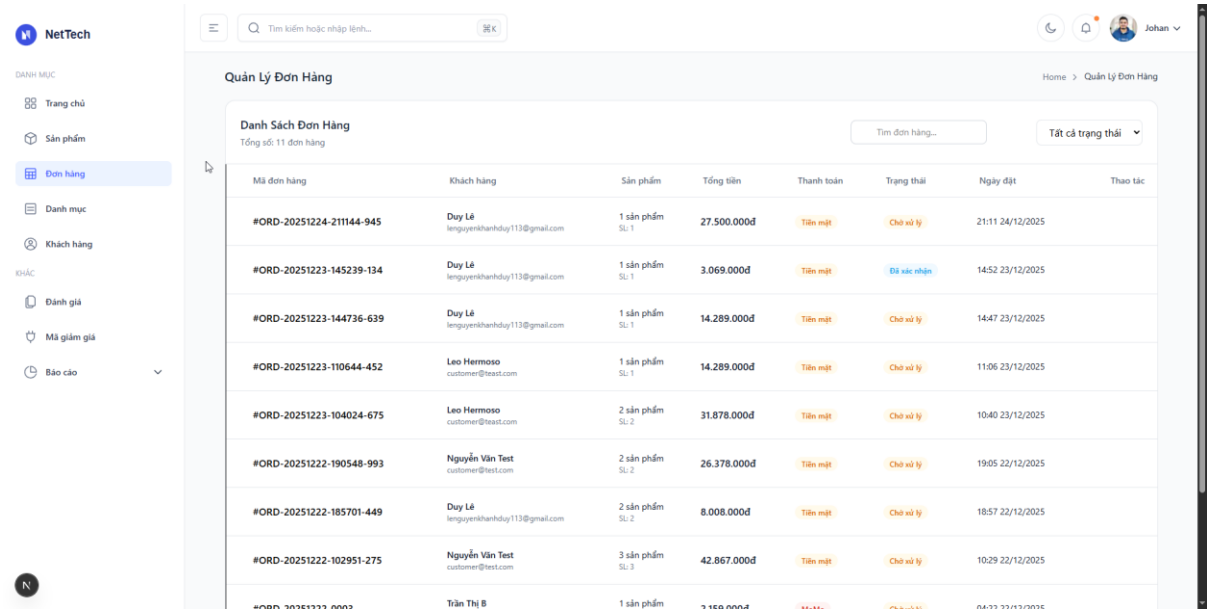
Giao diện quản trị được thiết kế nhằm hỗ trợ quản trị viên trong việc theo dõi và vận hành hệ thống. Các chức năng quản lý được tổ chức theo từng nhóm rõ ràng, giúp quản trị viên dễ dàng thao tác và kiểm soát dữ liệu.

Trang quản trị cho phép quản lý sản phẩm, danh mục và đơn hàng một cách tập trung, từ đó giúp giảm thiểu sai sót trong quá trình vận hành. Việc phân tách rõ giao diện quản trị và giao diện người dùng cũng góp phần nâng cao mức độ an toàn cho hệ thống.



Hình 23. Giao diện Dashboard Admin





Hình 24. Giao diện Quản lý đơn hàng

4.4. Những hạn chế của đề tài

Mặc dù đã đạt được các mục tiêu đề ra, hệ thống vẫn tồn tại một số hạn chế nhất định do giới hạn về thời gian và phạm vi nghiên cứu:

- Các cơ chế bảo mật nâng cao như xác thực hai yếu tố, giám sát và ghi log chi tiết chưa được triển khai.
- Hệ thống chưa tích hợp thanh toán trực tuyến thực tế.
- Giao diện người dùng chưa được tối ưu hoàn toàn cho nhiều loại thiết bị và kích thước màn hình khác nhau.
- Chưa thực hiện kiểm thử tải và đánh giá hiệu năng trong môi trường thực tế.

Những hạn chế này là điều khó tránh khỏi đối với một đồ án học phần, nhưng cũng là cơ sở để tiếp tục cải tiến hệ thống trong tương lai.

4.5. Hướng phát triển trong tương lai

Trong tương lai, hệ thống có thể được phát triển theo các hướng sau:

- Nâng cao bảo mật ứng dụng web bằng cách triển khai các cơ chế xác thực nâng cao và giám sát hệ thống.
- Mở rộng chức năng hệ thống như thanh toán trực tuyến, đánh giá sản phẩm và quản lý kho.
- Tối ưu hiệu năng hệ thống và khả năng mở rộng khi số lượng người dùng tăng cao.
- Triển khai và kiểm thử hệ thống trên môi trường thực tế để đánh giá mức độ ổn định và an toàn.

4.6. Tổng kết chương

Chương này đã tổng kết toàn bộ quá trình thực hiện đề tài, đánh giá các kết quả đạt được và chỉ ra những hạn chế còn tồn tại. Đồng thời, các hướng phát triển trong tương lai cũng được đề xuất nhằm nâng cao tính hoàn thiện và khả năng ứng dụng thực tế của hệ thống website bán thiết bị mạng đảm bảo an toàn thông tin.

TÀI LIỆU THAM KHẢO

[1] Implementingdatabasesecurityandauditing.pdf

[2] Database Security by Alfred Basta Melissa Zgola.pdf

[3] Web Application Security, A Beginners Guide by Bryan Sullivan, Vincent Liu.pdf

[4] The_web_application_hackers_handbook.pdf

BẢNG PHÂN CÔNG NHIỆM VỤ

Họ tên	MSSV	Nhiệm vụ
1. Lê Nguyễn Khánh Duy	N22DCAT012	- Lập trình backend & triển khai phòng chống các lổ hổng.
2.Thân Trung Tâm	N22DCAT047	- Lập trình frontend. - Kiểm thử bảo mật. - Tìm hiểu và đưa ra các biện pháp phòng chống về lổ hổng "Cross-Site Scripting".
3.Trần Công Hậu	N22DCAT020	- Xác định yêu cầu và phân tích hệ thống. - Thiết kế cơ sở dữ liệu - Tìm hiểu và đưa ra các biện pháp phòng chống về lổ hổng "Broken Authencation".
4.Nguyễn Quốc Vương	N22DCAT068	- Xác định yêu cầu và phân tích hệ thống. - Thiết kế cơ sở dữ liệu. - Tìm hiểu và đưa ra các biện pháp phòng chống về lổ hổng "Security Misconfiguration".
5.Nguyễn Phước Thanh	N22DCAT048	- Thiết kế cơ sở dữ liệu. - Kiểm thử chức năng. - Tìm hiểu và đưa ra các biện pháp phòng chống về lổ hổng "SQL Injection".